

Control AC-9: ser, upon successful logon, of changes to [Assignment: organization-defined security-related characteristics or parameters of the user's account] during [Assignment: organization-defined time period]. Discussion: Information about changes to security-related account characteristics within a specified time period allows users to recognize if changes were made without their knowledge. CHAPTER THREE PAGE 41 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Related Controls: None. (4) PREVIOUS LOGON NOTIFICATION | ADDITIONAL LOGON INFORMATION Notify the user, upon successful logon, of the following additional information: [Assignment: organization-defined additional information]. Discussion: Organizations can specify additional information to be provided to users upon logon, including the location of the last logon. User location is defined as information that can be determined by systems, such as Internet Protocol (IP) addresses from which network logons occurred, notifications of local logons, or device identifiers. Related Controls: None. References: None.

FedRAMP High Baseline · AC-4.4 · Flow Control of Encrypted Information Control Statement: Prevent encrypted information from bypassing [organization-defined parameter] by [organization-defined parameter]. Supplemental Guidance: Prevent encrypted information from bypassing [organization-defined parameter] by [organization-defined parameter]. Flow control mechanisms include content checking, security policy filters, and data type identifiers. The term encryption is extended to cover encoded data not recognized by filtering mechanisms. Assessment Objectives: Prevent encrypted information from bypassing [organization-defined parameter] by [organization-defined parameter]. FedRAMP Parameter Values: ac-04.04_odp.01: intrusion detection mechanisms ac-04.04_odp.03: the organization-defined procedure or method used to prevent encrypted information from bypassing information flow control mechanisms is defined (if selected);

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement enhances SP 800-171 requirement 03.01.02. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 PROTECTION STRATEGY 518

NIST SP 800-53 Rev 5 control AC-25 (Reference Monitor) is defined as follows: AC-25 · Reference Monitor Control Statement: Implement a reference monitor for [organization-defined parameter] that is tamperproof, always invoked, and small enough to be subject to analysis and testing, the completeness of which can be assured. Supplemental Guidance: Implement a reference monitor for [organization-defined parameter] that is tamperproof, always invoked, and small enough to be subject to analysis and testing, the completeness of which can be assured. A reference monitor is a set of design requirements on a reference validation mechanism that, as a key component of an operati

NIST SP 800-171 Rev 3 control 03.01.05 (03.01.05 Least Privilege) is assessed by examining the following: Assessment Objectives: - system access for users (or processes acting on behalf of users) is authorized only when necessary to accomplish assigned organizational tasks. - access to [organization-defined parameter] is authorized. - access to [organization-defined parameter] is authorized. - the privileges assigned to roles or classes of users are reviewed [organization-defined parameter] to validate the need for such privileges. - privileges are reassigned or removed, as necessary.

NIST SP 800-53 Rev 5 control AC-3.10 (Audited Override of Access Control Mechanisms) is assessed by examining, interviewing, and testing: AC-3.10 · Audited Override of Access Control Mechanisms Control Statement: Employ an audited override of automated access control mechanisms under [organization-defined parameter] by [organization-defined parameter]. Supplemental Guidance: Employ an audited override of automated access control mechanisms under [organization-defined parameter] by [organization-defined parameter]. In certain situations, such as when there is a threat to human life or an event that threatens the organization's ab

NIST SP 800-53 Rev 5 control AC-2.11 (Usage Conditions) is defined as follows: AC-2.11 · Usage Conditions Control Statement: Enforce [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: Enforce [organization-defined parameter] for [organization-defined parameter]. Specifying and enforcing usage conditions helps to enforce the principle of

least privilege, increase user accountability, and enable effective account monitoring. Account monitoring includes alerts generated if the account is used in violation of organizational parameters. Organizations can describe specific conditions or circumstances under which system accounts can

AC-4.8 · Security and Privacy Policy Filters Control Statement: (a) Enforce information flow control using [organization-defined parameter] as a basis for flow control decisions for [organization-defined parameter] ; and (b) [organization-defined parameter] data after a filter processing failure in accordance with [organization-defined parameter]. Supplemental Guidance: (a) Enforce information flow control using [organization-defined parameter] as a basis for flow control decisions for [organization-defined parameter] ; and (b) [organization-defined parameter] data after a filter processing failure in accordance with [organization-defined parameter]. Organization-defined security or privacy policy filters can address data structures and content. For example, security or privacy policy filters for data structures can check for maximum file lengths, maximum field sizes, and data/file types (for structured and unstructured data). Security or privacy policy filters for data content can check for specific words, enumerated values or data value ranges, and hidden content. Structured data permits the interpretation of data content by applications. Unstructured data refers to digital information without a data structure or with a data structure that does not facilitate the development of rule sets to address the impact or classification level of the information conveyed by the data or the flow enforcement decisions. Unstructured data consists of bitmap objects that are inherently non-language-based (i.e., image, video, or audio files) and textual objects that are based on written or printed languages. Organizations can implement more than one security or privacy policy filter to meet information flow control objectives.

NIST SP 800-171 Rev 3 control 03.01.03 (03.01.03 Information Flow Enforcement) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.01.04 (03.01.04 Separation of Duties) is assessed by examining the following: Assessment Objectives: - duties of individuals requiring separation are identified. - system access authorizations to support separation of duties are defined.

NIST SP 800-53 Rev 5 control AC-4.2 (Processing Domains) summarizes the requirements for this control: AC-4.2 · Processing Domains Control Statement: Use protected processing domains to enforce [organization-defined parameter] as a basis for flow control decisions. Supplemental Guidance: Use protected processing domains to enforce [organization-defined parameter] as a basis for flow control decisions. Protected processing domains within systems are processing spaces that have controlled interactions with other processing spaces, enabling control of information flows between these spaces and to/

NIST SP 800-53 Rev 5 control AC-9 (Previous Logon Notification): AC-9 · Previous Logon Notification Control Statement: Notify the user, upon successful logon to the system, of the date and time of the last logon. Supplemental Guidance: Notify the user, upon successful logon to the system, of the date and time of the last logon. Previous logon notification is applicable to system access via human user interfaces and access to systems that occurs in other types

NIST SP 800-171 Rev 3 control 03.01.04 (03.01.04 Separation of Duties) is assessed by examining the following: Assessment Objectives: - duties of individuals requiring separation are identified. - system access authorizations to support separation of duties are defined.

NIST SP 800-53 Rev 5 control AC-9.2 (Successful and Unsuccessful Logons) is defined as follows: AC-9.2 · Successful and Unsuccessful Logons Control Statement: Notify the user, upon successful logon, of the number of [organization-defined parameter] during [organization-defined parameter]. Supplemental Guidance: Notify the user, upon successful logon, of the number of [organization-defined parameter] during [organization-defined parameter]. Information about the number of successful and unsuccessful logon attempts within a specified time period allows the user to recognize if the number and type of logon attempts are consistent with the user's actual logon

attempts.

NIST SP 800-53 Rev 5 control AC-24 (Access Control Decisions) is assessed by examining, interviewing, and testing: AC-24 · Access Control Decisions Control Statement: [organization-defined parameter] to ensure [organization-defined parameter] are applied to each access request prior to access enforcement. Supplemental Guidance: [organization-defined parameter] to ensure [organization-defined parameter] are applied to each access request prior to access enforcement. Access control decisions (also known as authorization decisions) occur when authorization information is applied to specific accesses. In contr

AC-9.1 · Unsuccessful Logons Control Statement: Notify the user, upon successful logon, of the number of unsuccessful logon attempts since the last successful logon. Supplemental Guidance: Notify the user, upon successful logon, of the number of unsuccessful logon attempts since the last successful logon. Information about the number of unsuccessful logon attempts since the last successful logon allows the user to recognize if the number of unsuccessful logon attempts is consistent with the user's actual logon attempts.

AC-3 · Access Enforcement Control Statement: Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies. Supplemental Guidance: Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies. Access control policies control access between active entities or subjects (i.e., users or processes acting on behalf of users) and passive entities or objects (i.e., devices, files, records, domains) in organizational systems. In addition to enforcing authorized access at the system level and recognizing that systems can host many applications and services in support of mission and business functions, access enforcement mechanisms can also be employed at the application and service level to provide increased information security and privacy. In contrast to logical access controls that are implemented within the system, physical access controls are addressed by the controls in the Physical and Environmental Protection ([PE](#pe)) family.

NIST SP 800-53 Rev 5 control AC-4.12 (Data Type Identifiers) summarizes the requirements for this control: AC-4.12 · Data Type Identifiers Control Statement: When transferring information between different security domains, use [organization-defined parameter] to validate data essential for information flow decisions. Supplemental Guidance: When transferring information between different security domains, use [organization-defined parameter] to validate data essential for information flow decisions. Data type identifiers include filenames, file types, file signatures or tokens, and multiple interna

NIST SP 800-53 Rev 5 control AC-12.1 (User-initiated Logouts) summarizes the requirements for this control: AC-12.1 · User-initiated Logouts Control Statement: Provide a logout capability for user-initiated communications sessions whenever authentication is used to gain access to [organization-defined parameter]. Supplemental Guidance: Provide a logout capability for user-initiated communications sessions whenever authentication is used to gain access to [organization-defined parameter]. Information resources to which users gain access via authentication include local workstations, databases, and pa

NIST SP 800-171 Rev 3 control 03.01.11 (03.01.11 Session Termination) is assessed by examining the following: Assessment Objectives: - a user session is terminated automatically after [organization-defined parameter].

NIST SP 800-53 Rev 5 control AC-3.11 (Restrict Access to Specific Information Types) is assessed by examining, interviewing, and testing: AC-3.11 · Restrict Access to Specific Information Types Control Statement: Restrict access to data repositories containing [organization-defined parameter]. Supplemental Guidance: Restrict access to data repositories containing [organization-defined parameter]. Restricting access to specific information is intended to provide flexibility regarding access control of specific information types within a system. For example, role-based access could be employed to allow access to only a specific ty

FedRAMP High Baseline · AC-18.4 · Restrict Configurations by Users Control Statement: Identify and explicitly authorize users allowed to independently configure wireless networking capabilities.

Supplemental Guidance: Identify and explicitly authorize users allowed to independently configure wireless networking capabilities. Organizational authorizations to allow selected users to configure wireless networking capabilities are enforced, in part, by the access enforcement mechanisms employed within organizational systems. Assessment Objectives: Identify and explicitly authorize users allowed to independently configure wireless networking capabilities.

NIST SP 800-53 Rev 5 control AC-4.17 (Domain Authentication) is assessed by examining, interviewing, and testing: AC-4.17 · Domain Authentication Control Statement: Uniquely identify and authenticate source and destination points by [organization-defined parameter] for information transfer.

Supplemental Guidance: Uniquely identify and authenticate source and destination points by [organization-defined parameter] for information transfer. Attribution is a critical component of a security and privacy concept of operations. The ability to identify source and destination points for information flowing within

NIST SP 800-171 Rev 3 control 03.01.05 (03.01.05 Least Privilege) requires organizations to implement the following: Control Statement: SR-03.01.05.a Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks. SR-03.01.05.b Authorize access to [organization-defined parameter] and [organization-defined parameter]. SR-03.01.05.c Review the privileges assigned to roles or classes of users [organization-defined parameter] to validate the need for such privileges. SR-03.01.05.d Reassign or remove privileges, as necessary. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.05.

NIST SP 800-53 Rev 5 control AC-18.1 (Authentication and Encryption) is assessed by examining, interviewing, and testing: AC-18.1 · Authentication and Encryption Control Statement: Protect wireless access to the system using authentication of [organization-defined parameter] and encryption. Supplemental Guidance: Protect wireless access to the system using authentication of [organization-defined parameter] and encryption. Wireless networking capabilities represent a significant potential vulnerability that can be exploited by adversaries. To protect systems with wireless access points, strong authentication of us

NIST SP 800-171 Rev 3 control 03.01.03 (03.01.03 Information Flow Enforcement) is assessed by examining the following: Assessment Objectives: - approved authorizations are enforced for controlling the flow of CUI within the system. - approved authorizations are enforced for controlling the flow of CUI between connected systems.

NIST SP 800-53 Rev 5 control AC-4.29 (Filter Orchestration Engines) summarizes the requirements for this control: AC-4.29 · Filter Orchestration Engines Control Statement: When transferring information between different security domains, employ content filter orchestration engines to ensure that: (a) Content filtering mechanisms successfully complete execution without errors; and (b) Content filtering actions occur in the correct order and comply with [organization-defined parameter]. Supplemental Guidance: When transferring information between different security domains, employ content filter orchestrati

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Access Control 3.1.6 Privileged Account Management a. Restrict privileged accounts on the system to [Assignment: organization-defined personnel or roles] (03.01.06.a). b. Require that users (or roles) with privileged accounts use non-privileged accounts when accessing non-security functions or non-security information. Related Controls: AC-06(02), AC-06(05) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.06.a [Assignment: organization-defined personnel or roles] only defined and authorized personnel or administrative roles

NIST SP 800-53 Rev 5 control AC-9.1 (Unsuccessful Logons) is assessed by examining, interviewing, and testing: AC-9.1 · Unsuccessful Logons Control Statement: Notify the user, upon successful logon, of the number of unsuccessful logon attempts since the last successful logon. Supplemental Guidance: Notify the user, upon successful logon, of the number of unsuccessful logon attempts since the last successful logon. Information about the number of unsuccessful logon attempts since the last successful logon allows the user to recognize if the number of unsuccessful logon attempts is consistent with the us

NIST SP 800-171 Rev 3 control 03.01.16 (03.01.16 Wireless Access) is assessed by examining the following: Assessment Objectives: - each type of wireless access to the system is defined. - usage restrictions are established for each type of wireless access to the system. - configuration requirements are established for each type of wireless access to the system. - connection requirements are established for each type of wireless access to the system. - each type of wireless access to the system is authorized prior to establishing such connections. - wireless networking capabilities not intended for use are disabled prior to issuance and deployment. - wireless access to the system is protected using

Under the FedRAMP Moderate baseline, AC-6.1 (AC-6.1 Authorize Access to Security Functions): FedRAMP Moderate Baseline · AC-6.1 · Authorize Access to Security Functions Control Statement: Authorize access for [organization-defined parameter] to: (a) [organization-defined parameter] ; and (b) [organization-defined parameter]. Supplemental Guidance: Authorize access for [organization-defined parameter] to: (a) [organization-defined parameter] ; and (b) [organization-defined parameter]. Security functions include establishing system accounts, configuring access authorizations (i.e.,

NIST SP 800-53 Rev 5 control AC-21.1 (Automated Decision Support) is assessed by examining, interviewing, and testing: AC-21.1 · Automated Decision Support Control Statement: Employ [organization-defined parameter] to enforce information-sharing decisions by authorized users based on access authorizations of sharing partners and access restrictions on information to be shared. Supplemental Guidance: Employ [organization-defined parameter] to enforce information-sharing decisions by authorized users based on access authorizations of sharing partners and access restrictions on information to be shared. Automated

NIST SP 800-53 Rev 5 control AC-11 (Device Lock): AC-11 · Device Lock Control Statement: a. Prevent further access to the system by [organization-defined parameter] ; and b. Retain the device lock until the user reestablishes access using established identification and authentication procedures. Supplemental Guidance: a. Prevent further access to the system by [organization-defined parameter] ; and b. Retain the device lock until the user reest

AC-12 · Session Termination Control Statement: Automatically terminate a user session after [organization-defined parameter]. Supplemental Guidance: Automatically terminate a user session after [organization-defined parameter]. Session termination addresses the termination of user-initiated logical sessions (in contrast to [SC-10](#sc-10) , which addresses the termination of network connections associated with communications sessions (i.e., network disconnect)). A logical session (for local, network, and remote access) is initiated whenever a user (or process acting on behalf of a user) accesses an organizational system. Such user sessions can be terminated without terminating network sessions. Session termination ends all processes associated with a user's logical session except for those processes that are specifically created by the user (i.e., session owner) to continue after the session is terminated. Conditions or trigger events that require automatic termination of the session include organization-defined periods of user inactivity, targeted responses to certain types of incidents, or time-of-day restrictions on system use.

Under the FedRAMP High baseline, AC-2.2 (AC-2.2 Automated Temporary and Emergency Account Management): FedRAMP High Baseline · AC-2.2 · Automated Temporary and Emergency Account Management Control Statement: Automatically [organization-defined parameter] temporary and emergency accounts after [organization-defined parameter]. Supplemental Guidance: Automatically [organization-defined parameter] temporary and emergency accounts after [organization-defined parameter]. Management of temporary and emergency accounts includes the removal or disabling of such accounts automatically after a predefined

NIST SP 800-53 Rev 5 control AC-16.7 (Consistent Attribute Interpretation) is assessed by examining, interviewing, and testing: AC-16.7 · Consistent Attribute Interpretation Control Statement: Provide a consistent interpretation of security and privacy attributes transmitted between distributed system components. Supplemental Guidance: Provide a consistent interpretation of security and privacy attributes transmitted between distributed system components. To enforce security and privacy policies across multiple system components in distributed systems, organizations provide a consistent interpretation of security and p

Under the FedRAMP Moderate baseline, AC-17.3 (AC-17.3 Managed Access Control Points): FedRAMP Moderate Baseline · AC-17.3 · Managed Access Control Points Control Statement: Route remote accesses through authorized and managed network access control points. Supplemental Guidance: Route remote accesses through authorized and managed network access control points. Organizations consider the Trusted Internet Connections (TIC) initiative [DHS TIC](#4f42ee6e-86cc-403b-a51f-76c2b4f81b54) requirements for external network connections since limiting the number of access control points f

NIST SP 800-171 Rev 3 control 03.01.03 (03.01.03 Information Flow Enforcement) is assessed by examining the following: Assessment Objectives: - approved authorizations are enforced for controlling the flow of CUI within the system. - approved authorizations are enforced for controlling the flow of CUI between connected systems.

NIST SP 800-53 Rev 5 control AC-2.11 (Usage Conditions): AC-2.11 · Usage Conditions Control Statement: Enforce [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: Enforce [organization-defined parameter] for [organization-defined parameter]. Specifying and enforcing usage conditions helps to enforce the principle of least privilege, increase user accountability, and enable effective account monitoring. Account

Under the FedRAMP High baseline, AC-19 (AC-19 Access Control for Mobile Devices): FedRAMP High Baseline · AC-19 · Access Control for Mobile Devices Control Statement: a. Establish configuration requirements, connection requirements, and implementation guidance for organization-controlled mobile devices, to include when such devices are outside of controlled areas; and b. Authorize the connection of mobile devices to organizational systems. Supplemental Guidance: a. Establish configuration requirements, connection requirements, and implementation guidance for organization-co

Under the FedRAMP Moderate baseline, AC-2.2 (AC-2.2 Automated Temporary and Emergency Account Management): FedRAMP Moderate Baseline · AC-2.2 · Automated Temporary and Emergency Account Management Control Statement: Automatically [organization-defined parameter] temporary and emergency accounts after [organization-defined parameter]. Supplemental Guidance: Automatically [organization-defined parameter] temporary and emergency accounts after [organization-defined parameter]. Management of temporary and emergency accounts includes the removal or disabling of such accounts automatically after a predef

Under the FedRAMP High baseline, AC-22 (AC-22 Publicly Accessible Content): FedRAMP High Baseline · AC-22 · Publicly Accessible Content Control Statement: a. Designate individuals authorized to make information publicly accessible; b. Train authorized individuals to ensure that publicly accessible information does not contain nonpublic information; c. Review the proposed content of information prior to posting onto the publicly accessible system to ensure that nonpublic information is not included; and d. Review the content on the publicly accessible system for nonpubl

Implementing 03.01.03 (03.01.03 Information Flow Enforcement) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.01.03 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.01.03 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

AC-6.6 · Privileged Access by Non-organizational Users Control Statement: Prohibit privileged access to the system by non-organizational users. Supplemental Guidance: Prohibit privileged access to the system by non-organizational users. An organizational user is an employee or an individual considered by the organization to have the equivalent status of an employee. Organizational users include contractors, guest researchers, or individuals detailed from other organizations. A non-organizational user is a user who is not an organizational user. Policies and procedures for

granting equivalent status of employees to individuals include a need-to-know, citizenship, and the relationship to the organization.

Under the FedRAMP Low baseline, AC-7 (AC-7 Unsuccessful Logon Attempts): FedRAMP Low Baseline · AC-7 · Unsuccessful Logon Attempts Control Statement: a. Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during a [organization-defined parameter] ; and b. Automatically [organization-defined parameter] when the maximum number of unsuccessful attempts is exceeded. Supplemental Guidance: a. Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during a [organization-defined parameter]

NIST SP 800-171 Rev 3 control 03.01.11 (03.01.11 Session Termination) is assessed by examining the following: Assessment Objectives: - a user session is terminated automatically after [organization-defined parameter].

NIST SP 800-53 Rev 5 control AC-4.31 (Failed Content Transfer Prevention) summarizes the requirements for this control: AC-4.31 · Failed Content Transfer Prevention Control Statement: When transferring information between different security domains, prevent the transfer of failed content to the receiving domain. Supplemental Guidance: When transferring information between different security domains, prevent the transfer of failed content to the receiving domain. Content that failed filtering checks can corrupt the system if transferred to the receiving domain.

NIST SP 800-53 Rev 5 control AC-2.2 (Automated Temporary and Emergency Account Management) is defined as follows: AC-2.2 · Automated Temporary and Emergency Account Management Control Statement: Automatically [organization-defined parameter] temporary and emergency accounts after [organization-defined parameter]. Supplemental Guidance: Automatically [organization-defined parameter] temporary and emergency accounts after [organization-defined parameter]. Management of temporary and emergency accounts includes the removal or disabling of such accounts automatically after a predefined time period rather than at the convenience of the system administrator. Automatic removal or disabling of accounts provides

Implementing 03.01.20 (03.01.20 Use of External Systems) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.01.20 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.01.20 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control AC-16.5 (Attribute Displays on Objects to Be Output) is assessed by examining, interviewing, and testing: AC-16.5 · Attribute Displays on Objects to Be Output Control Statement: Display security and privacy attributes in human-readable form on each object that the system transmits to output devices to identify [organization-defined parameter] using [organization-defined parameter]. Supplemental Guidance: Display security and privacy attributes in human-readable form on each object that the system transmits to output devices to identify [organization-defined parameter] using [organization-defined parameter]

NIST SP 800-53 Rev 5 control AC-3.5 (Security-relevant Information) is assessed by examining, interviewing, and testing: AC-3.5 · Security-relevant Information Control Statement: Prevent access to [organization-defined parameter] except during secure, non-operable system states. Supplemental Guidance: Prevent access to [organization-defined parameter] except during secure, non-operable system states. Security-relevant information is information within systems that can potentially impact the operation of security functions or the provision of security services in a manner that could result in failure to enforce s

NIST SP 800-171 Rev 3 control 03.01.22 (03.01.22 Publicly Accessible Content) requires organizations

to implement the following: Control Statement: SR-03.01.22.a Train authorized individuals to ensure that publicly accessible information does not contain CUI. SR-03.01.22.b Review the content on publicly accessible systems for CUI and remove such information, if discovered. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.22.

NIST SP 800-53 Rev 5 control AC-2 (Account Management) summarizes the requirements for this control: AC-2 · Account Management Control Statement: a. Define and document the types of accounts allowed and specifically prohibited for use within the system; b. Assign account managers; c. Require [organization-defined parameter] for group and role membership; d. Specify: 1. Authorized users of the system; 2. Group and role membership; and 3. Access authorizations (i.e., privileges) and [organization-defined parameter] for each account; e. Require approvals by [organization-defined parameter]

NIST SP 800-53 Rev 5 control AC-6.5 (Privileged Accounts): AC-6.5 · Privileged Accounts Control Statement: Restrict privileged accounts on the system to [organization-defined parameter]. Supplemental Guidance: Restrict privileged accounts on the system to [organization-defined parameter]. Privileged accounts, including super user accounts, are typically described as system administrator for various types of commercial off-the-shelf operating systems. Re

Under the FedRAMP Low baseline, AC-19 (AC-19 Access Control for Mobile Devices): FedRAMP Low Baseline · AC-19 · Access Control for Mobile Devices Control Statement: a. Establish configuration requirements, connection requirements, and implementation guidance for organization-controlled mobile devices, to include when such devices are outside of controlled areas; and b. Authorize the connection of mobile devices to organizational systems. Supplemental Guidance: a. Establish configuration requirements, connection requirements, and implementation guidance for organization-con

NIST SP 800-53 Rev 5 control AC-10 (Concurrent Session Control) summarizes the requirements for this control: AC-10 · Concurrent Session Control Control Statement: Limit the number of concurrent sessions for each [organization-defined parameter] to [organization-defined parameter]. Supplemental Guidance: Limit the number of concurrent sessions for each [organization-defined parameter] to [organization-defined parameter]. Organizations may define the maximum number of concurrent sessions for system accounts globally, by account type, by account, or any combination thereof. For example, organizations ma

NIST SP 800-53 Rev 5 control AC-4.11 (Configuration of Security or Privacy Policy Filters) is defined as follows: AC-4.11 · Configuration of Security or Privacy Policy Filters Control Statement: Provide the capability for privileged administrators to configure [organization-defined parameter] to support different security or privacy policies. Supplemental Guidance: Provide the capability for privileged administrators to configure [organization-defined parameter] to support different security or privacy policies. Documentation contains detailed information for configuring security or privacy policy filters. For example, administrators can configure security or privacy policy filters to include the list o

NIST SP 800-171 Rev 3 control 03.01.07 (03.01.07 Least Privilege · Privileged Functions) requires organizations to implement the following: Control Statement: SR-03.01.07.a Prevent non-privileged users from executing privileged functions. SR-03.01.07.b Log the execution of privileged functions. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.07.

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement enhances SP 800-171 requirement 03.01.01. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 PROTECTION STRATEGY 549

NIST SP 800-53 Rev 5 control AC-9.2 (Successful and Unsuccessful Logons) summarizes the requirements for this control: AC-9.2 · Successful and Unsuccessful Logons Control Statement: Notify the user, upon successful logon, of the number of [organization-defined parameter] during [organization-defined parameter]. Supplemental Guidance: Notify the user, upon successful logon, of the number of

[organization-defined parameter] during [organization-defined parameter]. Information about the number of successful and unsuccessful logon attempts within a specified time period allows the user to recognize if the number a

NIST SP 800-53 Rev 5 control AC-9.3 (Notification of Account Changes) is assessed by examining, interviewing, and testing: AC-9.3 · Notification of Account Changes Control Statement: Notify the user, upon successful logon, of changes to [organization-defined parameter] during [organization-defined parameter]. Supplemental Guidance: Notify the user, upon successful logon, of changes to [organization-defined parameter] during [organization-defined parameter]. Information about changes to security-related account characteristics within a specified time period allows users to recognize if changes were made without the

NIST SP 800-171 Rev 3 control 03.01.12 (03.01.12 Remote Access) is assessed by examining the following: Assessment Objectives: - types of allowable remote system access are defined. - usage restrictions are established for each type of allowable remote system access. - configuration requirements are established for each type of allowable remote system access. - connection requirements are established for each type of allowable remote system access. - each type of remote system access is authorized prior to establishing such connections. - remote access to the system is routed through authorized access control points. - remote access to the system is routed through managed access control points.

NIST SP 800-53 Rev 5 control AC-11.1 (Pattern-hiding Displays) is defined as follows: AC-11.1 · Pattern-hiding Displays Control Statement: Conceal, via the device lock, information previously visible on the display with a publicly viewable image. Supplemental Guidance: Conceal, via the device lock, information previously visible on the display with a publicly viewable image. The pattern-hiding display can include static or dynamic images, such as patterns used with screen savers, photographic images, solid colors, clock, battery life indicator, or a blank screen with the caveat that controlled unclassified information is not displayed.

NIST SP 800-171 Rev 3 control 03.01.04 (03.01.04 Separation of Duties) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control AC-16.1 (Dynamic Attribute Association) summarizes the requirements for this control: AC-16.1 · Dynamic Attribute Association Control Statement: Dynamically associate security and privacy attributes with [organization-defined parameter] in accordance with the following security and privacy policies as information is created and combined: [organization-defined parameter]. Supplemental Guidance: Dynamically associate security and privacy attributes with [organization-defined parameter] in accordance with the following security and privacy policies as information is created and co

Under the FedRAMP High baseline, AC-2.5 (AC-2.5 Inactivity Logout): FedRAMP High Baseline · AC-2.5 · Inactivity Logout Control Statement: Require that users log out when [organization-defined parameter]. Supplemental Guidance: Require that users log out when [organization-defined parameter]. Inactivity logout is behavior- or policy-based and requires users to take physical action to log out when they are expecting inactivity longer than the defined period. Automatic enforcement of inactivity logout is addressed by [AC-11](#ac-11). Assessment Objectives: Requi

Under the FedRAMP High baseline, AC-4 (AC-4 Information Flow Enforcement): FedRAMP High Baseline · AC-4 · Information Flow Enforcement Control Statement: Enforce approved authorizations for controlling the flow of information within the system and between connected systems based on [organization-defined parameter]. Supplemental Guidance: Enforce approved authorizations for controlling the flow of information within the system and between connected systems based on [organization-defined parameter]. Information flow control regulates where information can travel within

NIST SP 800-53 Rev 5 control AC-16.2 (Attribute Value Changes by Authorized Individuals) is assessed by examining, interviewing, and testing: AC-16.2 · Attribute Value Changes by Authorized

Individuals Control Statement: Provide authorized individuals (or processes acting on behalf of individuals) the capability to define or change the value of associated security and privacy attributes. Supplemental Guidance: Provide authorized individuals (or processes acting on behalf of individuals) the capability to define or change the value of associated security and privacy attributes. The content or assigned values of attributes can directl

NIST SP 800-53 Rev 5 control AC-6.3 (Network Access to Privileged Commands) is assessed by examining, interviewing, and testing: AC-6.3 · Network Access to Privileged Commands Control Statement: Authorize network access to [organization-defined parameter] only for [organization-defined parameter] and document the rationale for such access in the security plan for the system. Supplemental Guidance: Authorize network access to [organization-defined parameter] only for [organization-defined parameter] and document the rationale for such access in the security plan for the system. Network access is any access across a netwo

AC-2.9 · Restrictions on Use of Shared and Group Accounts Control Statement: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Supplemental Guidance: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Before permitting the use of shared or group accounts, organizations consider the increased risk due to the lack of accountability with such accounts.

NIST SP 800-171 Rev 3 control 03.01.07 (03.01.07 Least Privilege · Privileged Functions) falls under the Access Control family. Control Statement: SR-03.01.07.a Prevent non-privileged users from executing privileged functions. SR-03.01.07.b Log the execution of privileged functions. Supplemental Guidance: Privileged functions include establishing system accounts, performing system integrity checks, conducting patching operations, changing system configuration settings, or administering cryptographic key management activities. Non-privileged users do not possess the authorizations to execute privileged functions. Bypassing intrusion detection and prevention mechanisms or malicious code protection mechanisms are examples of privileged functions that require protection from no

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Access Control 3.1.10 Device Lock a. Prevent access to the system by [Selection (one or more): initiating a device lock after [Assignment: organization-defined time period] (03.01.10.a) of inactivity; requiring the user to initiate a device lock before leaving the system unattended]. b. Retain the device lock until the user reestablishes access using established identification and authentication procedures. c. Conceal, via the device lock, information previously visible on the display with a publicly viewable image. Related Controls: AC-11, AC-11(01) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.10.a [Assignment: organization-defined time period] initiating a device lock after ·at most 15 minutes· of inactivity and requiring the user to initiate a devic

Under the FedRAMP Moderate baseline, AC-6.10 (AC-6.10 Prohibit Non-privileged Users from Executing Privileged Functions): FedRAMP Moderate Baseline · AC-6.10 · Prohibit Non-privileged Users from Executing Privileged Functions Control Statement: Prevent non-privileged users from executing privileged functions. Supplemental Guidance: Prevent non-privileged users from executing privileged functions. Privileged functions include disabling, circumventing, or altering implemented security or privacy controls, establishing system accounts, performing system integrity checks, and administering cryptographic key management

NIST SP 800-53 Rev 5 control AC-6.6 (Privileged Access by Non-organizational Users) summarizes the requirements for this control: AC-6.6 · Privileged Access by Non-organizational Users Control Statement: Prohibit privileged access to the system by non-organizational users. Supplemental Guidance: Prohibit privileged access to the system by non-organizational users. An organizational user is an employee or an individual considered by the organization to have the equivalent status of an employee. Organizational users include contractors, guest researchers, or individuals detailed from other organizations. A non-organization

Under the FedRAMP High baseline, AC-12 (AC-12 Session Termination): FedRAMP High Baseline · AC-12 · Session Termination Control Statement: Automatically terminate a user session after [organization-defined parameter]. Supplemental Guidance: Automatically terminate a user session after [organization-defined parameter]. Session termination addresses the termination of user-initiated

logical sessions (in contrast to [SC-10](#sc-10) , which addresses the termination of network connections associated with communications sessions (i.e., network disconnect)). A logic

NIST SP 800-53 Rev 5 control AC-4.9 (Human Reviews) is assessed by examining, interviewing, and testing: AC-4.9 · Human Reviews Control Statement: Enforce the use of human reviews for [organization-defined parameter] under the following conditions: [organization-defined parameter]. Supplemental Guidance: Enforce the use of human reviews for [organization-defined parameter] under the following conditions: [organization-defined parameter]. Organizations define security or privacy policy filters for all situations where automated flow control decisions are possible. When a fully automated flow contr

FedRAMP High Baseline · AC-4.21 · Physical or Logical Separation of Information Flows Control Statement: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Supplemental Guidance: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Enforcing the separation of information flows associated with defined types of data can enhance protection by ensuring that information is not commingled while in transit and by enabling flow control by transmission paths that are not otherwise achievable. Types of separable information include inbound and outbound communications traffic, service requests and responses, and information of differing security impact or classification levels. Assessment Objectives: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. FedRAMP Parameter Values: ac-4.21_prm_1: organization-defined mechanisms and/or techniques ac-04.21_odp.01: mechanisms and/or techniques used to logically separate information flows are defined (if selected); ac-04.21_odp.02: mechanisms and/or techniques used to physically separate information flows are defined (if selected); ac-04.21_odp.03: required separations by types of information are defined;

NIST SP 800-53 Rev 5 control AC-5 (Separation of Duties) is assessed by examining, interviewing, and testing: AC-5 · Separation of Duties Control Statement: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Supplemental Guidance: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Separation of duties addresses the potential for abuse of authorized privileges and helps to reduce the risk of malevolent activity without collusion. Separ

NIST SP 800-53 Rev 5 control AC-2.5 (Inactivity Logout) is defined as follows: AC-2.5 · Inactivity Logout Control Statement: Require that users log out when [organization-defined parameter]. Supplemental Guidance: Require that users log out when [organization-defined parameter]. Inactivity logout is behavior- or policy-based and requires users to take physical action to log out when they are expecting inactivity longer than the defined period. Automatic enforcement of inactivity logout is addressed by [AC-11](#ac-11).

NIST SP 800-53 Rev 5 control AC-4.28 (Linear Filter Pipelines) summarizes the requirements for this control: AC-4.28 · Linear Filter Pipelines Control Statement: When transferring information between different security domains, implement a linear content filter pipeline that is enforced with discretionary and mandatory access controls. Supplemental Guidance: When transferring information between different security domains, implement a linear content filter pipeline that is enforced with discretionary and mandatory access controls. Content filtering is the process of inspecting information as it travel

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Access Control 3.1.5 System Access Authorization a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks. b. Authorize access to: 1. [Assignment: organization-defined security functions] (03.01.05.b.01), and 2. [Assignment: organization-defined security-relevant information] (03.01.05.b.02). c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency](03.01.05.c) to validate the need for such privileges. d. Reassign or remove privileges, as necessary. Related Controls: AC-06, AC-06(01), AC-06(07), AU-09(04) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.05.b.01 [Assignment: organization- defined security functions]

NIST SP 800-171 Rev 3 control 03.01.06 (03.01.06 Least Privilege · Privileged Accounts) requires organizations to implement the following: Control Statement: SR-03.01.06.a Restrict privileged accounts on the system to [organization-defined parameter].. SR-03.01.06.b Require that users (or roles) with privileged accounts use non-privileged accounts when accessing non-security functions or non-security information. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.06.

NIST SP 800-53 Rev 5 control AC-12 (Session Termination): AC-12 · Session Termination Control Statement: Automatically terminate a user session after [organization-defined parameter]. Supplemental Guidance: Automatically terminate a user session after [organization-defined parameter]. Session termination addresses the termination of user-initiated logical sessions (in contrast to [SC-10](#sc-10) , which addresses the termination of network connections

NIST SP 800-53 Rev 5 control AC-4.22 (Access Only) summarizes the requirements for this control: AC-4.22 · Access Only Control Statement: Provide access from a single device to computing platforms, applications, or data residing in multiple different security domains, while preventing information flow between the different security domains. Supplemental Guidance: Provide access from a single device to computing platforms, applications, or data residing in multiple different security domains, while preventing information flow between the different security domains. The system provides a ca

NIST SP 800-171 Rev 3 control 03.01.04 (03.01.04 Separation of Duties) requires organizations to implement the following: Control Statement: SR-03.01.04.a Identify the duties of individuals requiring separation. SR-03.01.04.b Define system access authorizations to support separation of duties. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.04.

NIST SP 800-53 Rev 5 control AC-4.30 (Filter Mechanisms Using Multiple Processes) summarizes the requirements for this control: AC-4.30 · Filter Mechanisms Using Multiple Processes Control Statement: When transferring information between different security domains, implement content filtering mechanisms using multiple processes. Supplemental Guidance: When transferring information between different security domains, implement content filtering mechanisms using multiple processes. The use of multiple processes to implement content filtering mechanisms reduces the likelihood of a single point of failure.

NIST SP 800-53 Rev 5 control AC-17.4 (Privileged Commands and Access) is defined as follows: AC-17.4 · Privileged Commands and Access Control Statement: (a) Authorize the execution of privileged commands and access to security-relevant information via remote access only in a format that provides assessable evidence and for the following needs: [organization-defined parameter] ; and (b) Document the rationale for remote access in the security plan for the system. Supplemental Guidance: (a) Authorize the execution of privileged commands and access to security-relevant information via remote access only in a format that provides assessable evidence and for the following needs: [organiz

NIST SP 800-53 Rev 5 control AC-3.7 (Role-based Access Control) is assessed by examining, interviewing, and testing: AC-3.7 · Role-based Access Control Control Statement: Enforce a role-based access control policy over defined subjects and objects and control access based upon [organization-defined parameter]. Supplemental Guidance: Enforce a role-based access control policy over defined subjects and objects and control access based upon [organization-defined parameter]. Role-based access control (RBAC) is an access control policy that enforces access to objects and system functions based on the defined role

AC-6.10 · Prohibit Non-privileged Users from Executing Privileged Functions Control Statement: Prevent non-privileged users from executing privileged functions. Supplemental Guidance: Prevent non-privileged users from executing privileged functions. Privileged functions include disabling, circumventing, or altering implemented security or privacy controls, establishing system accounts, performing system integrity checks, and administering cryptographic key management activities. Non-privileged users are individuals who do not possess appropriate authorizations. Privileged functions

that require protection from non-privileged users include circumventing intrusion detection and prevention mechanisms or malicious code protection mechanisms. Preventing non-privileged users from executing privileged functions is enforced by [AC-3](#ac-3).

NIST SP 800-53 Rev 5 control AC-24.1 (Transmit Access Authorization Information) is assessed by examining, interviewing, and testing: AC-24.1 · Transmit Access Authorization Information Control Statement: Transmit [organization-defined parameter] using [organization-defined parameter] to [organization-defined parameter] that enforce access control decisions. Supplemental Guidance: Transmit [organization-defined parameter] using [organization-defined parameter] to [organization-defined parameter] that enforce access control decisions. Authorization processes and access control decisions may occur in separate parts of systems

NIST SP 800-53 Rev 5 control AC-8 (System Use Notification) is assessed by examining, interviewing, and testing: AC-8 · System Use Notification Control Statement: a. Display [organization-defined parameter] to users before granting access to the system that provides privacy and security notices consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines and state that: 1. Users are accessing a U.S. Government system; 2. System usage may be monitored, recorded, and subject to audit; 3. Unauthorized use of the system is prohibited and subject to crim

NIST SP 800-171 Rev 3 control 03.01.08 (03.01.08 Unsuccessful Logon Attempts) requires organizations to implement the following: Control Statement: SR-03.01.08.a Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during a [organization-defined parameter]. SR-03.01.08.b Automatically [organization-defined parameter] when the maximum number of unsuccessful attempts is exceeded. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.08.

| 5.2.1 | Scenario 1: Protect Host from Malware Infection via
USB..... | 37 | |-----|-----|
-----|-----| 5.2.2 |

Scenario 2: Protect Host from Malware Infection via Network Vector..... | 37 | | 5.2.3
| Scenario 3: Protect Host from Malware via Remote Access Connections | 39 | | 5.2.4 |
Scenario 4: Protect Host from Unauthorized Application Installation | 40 | |
5.2.5 | Scenario 5: Protect from Unauthorized Addition of a Device
| 42 | | 5.2.6 | Scenario 6: Detect Unauthorized Device-to-Device Communications.....
| 43 | | 5.2.7 | Scenario 7: Protect from Unauthorized Deletion of
Files..... | 43 | | 5.2.8 | Scenario 8: Detect Unauthorized
Modification of PLC Logic..... | 45 | | 5.2.9 | Scenario 9: Protect
from Modification of Historian Data..... | 46 | | 5.3.1 | PR.AC-1:
Identities and Credentials are Issued, Managed, Verified, Revoked, and Audited for Authorized
Devices, Users, and Processes..... | 50 | | 5.3.2 | PR.AC-3: Remote Access is
Managed | 50 | | 5.3.3 |
PR.AC-4: Access Permissions and Authorizations are Managed, Incorporating the Principles of Least
Privilege and Separation of Duties

Under the FedRAMP Moderate baseline, AC-5 (AC-5 Separation of Duties): FedRAMP Moderate Baseline · AC-5 · Separation of Duties Control Statement: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Supplemental Guidance: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Separation of duties addresses the potential for abuse of authorized privileges and helps to reduce the risk of malevolent activ

NIST SP 800-53 Rev 5 control AC-24.1 (Transmit Access Authorization Information) summarizes the requirements for this control: AC-24.1 · Transmit Access Authorization Information Control Statement: Transmit [organization-defined parameter] using [organization-defined parameter] to [organization-defined parameter] that enforce access control decisions. Supplemental Guidance: Transmit [organization-defined parameter] using [organization-defined parameter] to [organization-defined parameter] that enforce access control decisions. Authorization processes and access control

decisions may occur in separate parts of systems

Under the FedRAMP High baseline, AC-17 (AC-17 Remote Access): FedRAMP High Baseline · AC-17 · Remote Access Control Statement: a. Establish and document usage restrictions, configuration/connection requirements, and implementation guidance for each type of remote access allowed; and b. Authorize each type of remote access to the system prior to allowing such connections. Supplemental Guidance: a. Establish and document usage restrictions, configuration/connection requirements, and implementation guidance for each type of remote access allowed; and b. Aut

NIST SP 800-171 Rev 3 control 03.01.10 (03.01.10 Device Lock) falls under the Access Control family. Control Statement: SR-03.01.10.a Prevent access to the system by [organization-defined parameter]. SR-03.01.10.b Retain the device lock until the user reestablishes access using established identification and authentication procedures. SR-03.01.10.c Conceal, via the device lock, information previously visible on the display with a publicly viewable image. Supplemental Guidance: Device locks are temporary actions taken to prevent access to the system when users depart from the immediate vicinity of the system but do not want to log out due to the temporary nature of their absences. Device locks can be implemented at the operating system level or application level. User-initiated device locking is behavior- or policy-based and requires users to take physical action to initiate the device lock. Device locks are not an acceptable substitute for loggi

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY 549 P RA, DLO ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-02(04) 03.0 1.08E Account Monitoring for Atypical Usage a. Monitor system accounts for [Assignment: organization-defined atypical usage]. b. Report atypical usage of system accounts to [Assignment: organization-defined personnel or roles]. DISCUSSION Atypical usage includes accessing systems at certain times of the day or from locations that are not consistent with the normal usage patterns of individuals. Monitoring for atypical usage may reveal rogue behavior by individuals or an attack in progress. This requirement enhances SP 800-171 requirement 03.01.01. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Expose (Detect) REFERENCES Source Control: AC-02(12)

Under the FedRAMP High baseline, AC-18.5 (AC-18.5 Antennas and Transmission Power Levels): FedRAMP High Baseline · AC-18.5 · Antennas and Transmission Power Levels Control Statement: Select radio antennas and calibrate transmission power levels to reduce the probability that signals from wireless access points can be received outside of organization-controlled boundaries. Supplemental Guidance: Select radio antennas and calibrate transmission power levels to reduce the probability that signals from wireless access points can be received outside of organization-controlled boundaries.

NIST SP 800-53 Rev 5 control AC-4 (Information Flow Enforcement) is assessed by examining, interviewing, and testing: AC-4 · Information Flow Enforcement Control Statement: Enforce approved authorizations for controlling the flow of information within the system and between connected systems based on [organization-defined parameter]. Supplemental Guidance: Enforce approved authorizations for controlling the flow of information within the system and between connected systems based on [organization-defined parameter]. Information flow control regulates where information can travel within a system and between sy

NIST SP 800-53 Rev 5 control AC-4.6 (Metadata) summarizes the requirements for this control: AC-4.6 · Metadata Control Statement: Enforce information flow control based on [organization-defined parameter]. Supplemental Guidance: Enforce information flow control based on [organization-defined parameter]. Metadata is information that describes the characteristics of data. Metadata can include structural metadata describing data structures or descriptive metadata describing data content. Enforcement of allowed information flows based on metadata enables simpler and more effective flow co

Under the FedRAMP Moderate baseline, AC-20 (AC-20 Use of External Systems): FedRAMP Moderate Baseline · AC-20 · Use of External Systems Control Statement: a. [organization-defined parameter] , consistent with the trust relationships established with other organizations owning, operating, and/or maintaining external systems, allowing authorized individuals to: 1. Access the system from external systems; and 2. Process, store, or transmit organization-controlled information using

external systems; or b. Prohibit the use of [organization-defined parameter]. Supplement

NIST SP 800-171 Rev 3 control 03.01.10 (03.01.10 Device Lock) requires organizations to implement the following: Control Statement: SR-03.01.10.a Prevent access to the system by [organization-defined parameter]. SR-03.01.10.b Retain the device lock until the user reestablishes access using established identification and authentication procedures. SR-03.01.10.c Conceal, via the device lock, information previously visible on the display with a publicly viewable image. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.10.

NIST SP 800-53 Rev 5 control AC-17.2 (Protection of Confidentiality and Integrity Using Encryption) summarizes the requirements for this control: AC-17.2 · Protection of Confidentiality and Integrity Using Encryption Control Statement: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Supplemental Guidance: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Virtual private networks can be used to protect the confidentiality and integrity of remote access sessions. Transport Layer Security (TLS) is an example of a cryptographi

NIST SP 800-171 Rev 3 control 03.01.02 (03.01.02 Access Enforcement) requires organizations to implement the following: 03.01.02 · Access Enforcement Supplemental Guidance: Access control policies control access between active entities or subjects (i.e., users or system processes acting on behalf of users) and passive entities or objects (i.e., devices, files, records, domains) in organizational systems. Types of system access include remote access and access to systems that communicate through external networks, such as the internet. Access enforcement mechanisms can also be employed at the application and serv For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.02.

NIST SP 800-171 Rev 3 control 03.01.08 (03.01.08 Unsuccessful Logon Attempts) requires organizations to implement the following: Control Statement: SR-03.01.08.a Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during a [organization-defined parameter]. SR-03.01.08.b Automatically [organization-defined parameter] when the maximum number of unsuccessful attempts is exceeded. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.08.

NIST SP 800-171 Rev 3 control 03.01.09 (03.01.09 System Use Notification) falls under the Access Control family. 03.01.09 · System Use Notification Supplemental Guidance: System use notifications can be implemented using messages or warning banners. The messages or warning banners are displayed before individuals log in to a system that processes, stores, or transmits CUI. System use notifications are used for access via logon interfaces with human users and are not required when human interfaces do not exist. Organizations consider whether a secondary use notification is needed to access applications or Supplemental Guidance: System use notifications can be implemented using messages or warning banners. The messages or warning banners are displayed before individuals log in to a system that processes, stores, or transmits CUI. System use notifications are used for access via logon interfaces with human users and are not required when human interfaces do not exist. Organizations consider whether a secondary use notification is needed to access applications or other system resources after the ini

Under the FedRAMP Moderate baseline, AC-19 (AC-19 Access Control for Mobile Devices): FedRAMP Moderate Baseline · AC-19 · Access Control for Mobile Devices Control Statement: a. Establish configuration requirements, connection requirements, and implementation guidance for organization-controlled mobile devices, to include when such devices are outside of controlled areas; and b. Authorize the connection of mobile devices to organizational systems. Supplemental Guidance: a. Establish configuration requirements, connection requirements, and implementation guidance for organizatio

From the NIST SP 800-172 Rev 3 Final Public Draft: Data type identifiers include filenames, file types, file signatures or tokens, and multiple internal file signatures or tokens. Systems only allow for the transfer of data that is compliant with data type format specifications. The

identification and validation of data types is based on defined specifications associated with each allowed data format. The filename and number alone are not used for data type identification. Content is validated syntactically and semantically against its specification to ensure that it is the proper data type. This requirement enhances SP 800-171 requirement 03.01.03. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-04(12) 03.0 1.16E Decomposition Into Policy-Relevant Subcomponents De

NIST SP 800-53 Rev 5 control AC-19.5 (Full Device or Container-based Encryption) is assessed by examining, interviewing, and testing: AC-19.5 · Full Device or Container-based Encryption Control Statement: Employ [organization-defined parameter] to protect the confidentiality and integrity of information on [organization-defined parameter]. Supplemental Guidance: Employ [organization-defined parameter] to protect the confidentiality and integrity of information on [organization-defined parameter]. Container-based encryption provides a more fine-grained approach to data and information encryption on mobile devices, including e

NIST SP 800-53 Rev 5 control AC-7.3 (Biometric Attempt Limiting) is assessed by examining, interviewing, and testing: AC-7.3 · Biometric Attempt Limiting Control Statement: Limit the number of unsuccessful biometric logon attempts to [organization-defined parameter]. Supplemental Guidance: Limit the number of unsuccessful biometric logon attempts to [organization-defined parameter]. Biometrics are probabilistic in nature. The ability to successfully authenticate can be impacted by many factors, including matching performance and presentation attack detection mechanisms. Organizations select the appropriate nu

NIST SP 800-53 Rev 5 control AC-11 (Device Lock) summarizes the requirements for this control: AC-11 · Device Lock Control Statement: a. Prevent further access to the system by [organization-defined parameter] ; and b. Retain the device lock until the user reestablishes access using established identification and authentication procedures. Supplemental Guidance: a. Prevent further access to the system by [organization-defined parameter] ; and b. Retain the device lock until the user reestablishes access using established identification and authentication procedures. Device locks are tem

NIST SP 800-53 Rev 5 control AC-16.8 (Association Techniques and Technologies) is assessed by examining, interviewing, and testing: AC-16.8 · Association Techniques and Technologies Control Statement: Implement [organization-defined parameter] in associating security and privacy attributes to information. Supplemental Guidance: Implement [organization-defined parameter] in associating security and privacy attributes to information. The association of security and privacy attributes to information within systems is important for conducting automated access enforcement and flow enforcement actions. The association of such at

NIST SP 800-53 Rev 5 control AC-17.1 (Monitoring and Control): AC-17.1 · Monitoring and Control Control Statement: Employ automated mechanisms to monitor and control remote access methods. Supplemental Guidance: Employ automated mechanisms to monitor and control remote access methods. Monitoring and control of remote access methods allows organizations to detect attacks and help ensure compliance with remote access policies by auditing the connection activi

NIST SP 800-53 Rev 5 control AC-16.4 (Association of Attributes by Authorized Individuals) is assessed by examining, interviewing, and testing: AC-16.4 · Association of Attributes by Authorized Individuals Control Statement: Provide the capability to associate [organization-defined parameter] with [organization-defined parameter] by authorized individuals (or processes acting on behalf of individuals). Supplemental Guidance: Provide the capability to associate [organization-defined parameter] with [organization-defined parameter] by authorized individuals (or processes acting on behalf of individuals). Systems, in general, provide the

NIST SP 800-53 Rev 5 control AC-17.9 (Disconnect or Disable Access) summarizes the requirements for this control: AC-17.9 · Disconnect or Disable Access Control Statement: Provide the capability to disconnect or disable remote access to the system within [organization-defined parameter]. Supplemental Guidance: Provide the capability to disconnect or disable remote access to the system within [organization-defined parameter]. The speed of system disconnect or disablement varies based on the criticality of missions or business functions and the need to eliminate immediate or future remote access to systems.

NIST SP 800-53 Rev 5 control AC-16.2 (Attribute Value Changes by Authorized Individuals) summarizes the requirements for this control: AC-16.2 · Attribute Value Changes by Authorized Individuals
Control Statement: Provide authorized individuals (or processes acting on behalf of individuals) the capability to define or change the value of associated security and privacy attributes.
Supplemental Guidance: Provide authorized individuals (or processes acting on behalf of individuals) the capability to define or change the value of associated security and privacy attributes. The content or assigned values of attributes can directl

NIST SP 800-171 Rev 3 control 03.01.11 (03.01.11 Session Termination) falls under the Access Control family. 03.01.11 · Session Termination Supplemental Guidance: This requirement addresses the termination of user-initiated logical sessions in contrast to the termination of network connections that are associated with communications sessions (i.e., disconnecting from the network) in [(#/cpirt/framework/version/SP_800_171_3_0_0/home?element=03.13.09)03.13.09. A logical session is initiated whenever a user (or processes acting on behalf of a user) accesses a system. Logical sessions can be terminated (a Supplemental Guidance: This requirement addresses the termination of user-initiated logical sessions in contrast to the termination of network connections that are associated with communications sessions (i.e., disconnecting from the network) in [(#/cpirt/framework/version/SP_800_171_3_0_0/home?element=03.13.09)03.13.09. A logical session is initiated whenever a user (or processes acting on behalf of a user) accesses a system. Logical sessions can be terminated (and thus terminate user access) w

Under the FedRAMP High baseline, AC-5 (AC-5 Separation of Duties): FedRAMP High Baseline · AC-5 · Separation of Duties Control Statement: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Supplemental Guidance: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Separation of duties addresses the potential for abuse of authorized privileges and helps to reduce the risk of malevolent activity

NIST SP 800-53 Rev 5 control AC-2.12 (Account Monitoring for Atypical Usage) summarizes the requirements for this control: AC-2.12 · Account Monitoring for Atypical Usage Control Statement: (a) Monitor system accounts for [organization-defined parameter] ; and (b) Report atypical usage of system accounts to [organization-defined parameter]. Supplemental Guidance: (a) Monitor system accounts for [organization-defined parameter] ; and (b) Report atypical usage of system accounts to [organization-defined parameter]. Atypical usage includes accessing systems at certain times of the day or from locations that are not c

NIST SP 800-53 Rev 5 control AC-4.22 (Access Only) is defined as follows: AC-4.22 · Access Only Control Statement: Provide access from a single device to computing platforms, applications, or data residing in multiple different security domains, while preventing information flow between the different security domains. Supplemental Guidance: Provide access from a single device to computing platforms, applications, or data residing in multiple different security domains, while preventing information flow between the different security domains. The system provides a capability for users to access each connected security domain without providing any mechanisms to allo

NIST SP 800-53 Rev 5 control AC-4.3 (Dynamic Information Flow Control) is assessed by examining, interviewing, and testing: AC-4.3 · Dynamic Information Flow Control Control Statement: Enforce [organization-defined parameter]. Supplemental Guidance: Enforce [organization-defined parameter]. Organizational policies regarding dynamic information flow control include allowing or disallowing information flows based on changing conditions or mission or operational considerations. Changing conditions include changes in risk tolerance due to changes in the immediacy of mission or business needs, changes in the threat envi

NIST SP 800-53 Rev 5 control AC-9 (Previous Logon Notification) summarizes the requirements for this control: AC-9 · Previous Logon Notification Control Statement: Notify the user, upon successful logon to the system, of the date and time of the last logon. Supplemental Guidance: Notify the user, upon successful logon to the system, of the date and time of the last logon. Previous logon notification is applicable to system access via human user interfaces and access to systems that occurs in other types of architectures. Information about the last successful logon allows the user to recognize if the d

NIST SP 800-53 Rev 5 control AC-4.30 (Filter Mechanisms Using Multiple Processes) is assessed by examining, interviewing, and testing: AC-4.30 · Filter Mechanisms Using Multiple Processes Control Statement: When transferring information between different security domains, implement content filtering mechanisms using multiple processes. Supplemental Guidance: When transferring information between different security domains, implement content filtering mechanisms using multiple processes. The use of multiple processes to implement content filtering mechanisms reduces the likelihood of a single point of failure.

Under the FedRAMP High baseline, AC-10 (AC-10 Concurrent Session Control): FedRAMP High Baseline · AC-10 · Concurrent Session Control Control Statement: Limit the number of concurrent sessions for each [organization-defined parameter] to [organization-defined parameter]. Supplemental Guidance: Limit the number of concurrent sessions for each [organization-defined parameter] to [organization-defined parameter]. Organizations may define the maximum number of concurrent sessions for system accounts globally, by account type, by account, or any combination thereof. For e

NIST SP 800-171 Rev 3 control 03.01.18 (03.01.18 Access Control for Mobile Devices) is assessed by examining the following: Assessment Objectives: - usage restrictions are established for mobile devices. - configuration requirements are established for mobile devices. - connection requirements are established for mobile devices. - the connection of mobile devices to the system is authorized. - full-device or container-based encryption is implemented to protect the confidentiality of CUI on mobile devices.

NIST SP 800-171 Rev 3 control 03.01.06 (03.01.06 Least Privilege · Privileged Accounts) is assessed by examining the following: Assessment Objectives: - privileged accounts on the system are restricted to [organization-defined parameter]. - users (or roles) with privileged accounts are required to use non-privileged accounts when accessing non-security functions or non-security information.

From the NIST SP 800-172 Rev 3 Final Public Draft: Source Control: AC-20(03) 03.01.03E Withdrawn Addressed by 03.01.09E, 03.01.10E, and 03.01.03 (SP 800-171). 03.01.04E Concurrent Session Control Limit the number of concurrent sessions for each [Assignment: organization-defined account and/or account type] to [Assignment: organization-defined number]. DISCUSSION Organizations may define the maximum number of concurrent sessions for system accounts globally, by account type, by account, or any combination thereof. For example, organizations may limit the number of concurrent sessions for system administrators or other individuals working in particularly sensitive domains or mission-critical applications. Concurrent session control addresses concurrent sessions for system accounts. It does not, however, address concurrent sess

AC-2.12 · Account Monitoring for Atypical Usage Control Statement: (a) Monitor system accounts for [organization-defined parameter] ; and (b) Report atypical usage of system accounts to [organization-defined parameter]. Supplemental Guidance: (a) Monitor system accounts for [organization-defined parameter] ; and (b) Report atypical usage of system accounts to [organization-defined parameter]. Atypical usage includes accessing systems at certain times of the day or from locations that are not consistent with the normal usage patterns of individuals. Monitoring for atypical usage may reveal rogue behavior by individuals or an attack in progress. Account monitoring may inadvertently create privacy risks since data collected to identify atypical usage may reveal previously unknown information about the behavior of individuals. Organizations assess and document privacy risks from monitoring accounts for atypical usage in their privacy impact assessment and make determinations that are in alignment with their privacy program plan.

NIST SP 800-171 Rev 3 control 03.01.16 (03.01.16 Wireless Access) is assessed by examining the following: Assessment Objectives: - each type of wireless access to the system is defined. - usage restrictions are established for each type of wireless access to the system. - configuration requirements are established for each type of wireless access to the system. - connection requirements are established for each type of wireless access to the system. - each type of wireless access to the system is authorized prior to establishing such connections. - wireless networking capabilities not intended for use are disabled prior to issuance and deployment. - wireless access to the system is protected using

NIST SP 800-171 Rev 3 control 03.01.02 (03.01.02 Access Enforcement) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP Moderate baseline, AC-7 (AC-7 Unsuccessful Logon Attempts): FedRAMP Moderate Baseline · AC-7 · Unsuccessful Logon Attempts Control Statement: a. Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during a [organization-defined parameter] ; and b. Automatically [organization-defined parameter] when the maximum number of unsuccessful attempts is exceeded. Supplemental Guidance: a. Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during a [organization-defined pa

NIST SP 800-53 Rev 5 control AC-3 (Access Enforcement) summarizes the requirements for this control: AC-3 · Access Enforcement Control Statement: Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies. Supplemental Guidance: Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies. Access control policies control access between active entities or subjects (i.e., users or processes acting on behalf of users) and passive entiti

and CHAPTER THREE PAGE 308 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

b.

Implement the following types of cryptography required for each specified cryptographic use: [Assignment: organization-defined types of cryptography for each specified cryptographic use]. Discussion: Cryptography can be employed to support a variety of security solutions, including the protection of classified information and controlled unclassified information, the provision and implementation of digital signatures, and the enforcement of information separation when authorized individuals have the necessary clearances but lack the necessary formal access approvals. Cryptography can also be used to support random number and hash generation. Generally applicable cryptographic standards include FIPS-validated cryptography and NSA- approved cryptography. For example, organizations that need to protect classified information may specify the use of NSA- approved cryptography. Organizations that need to provision and implement digital signatures may specify the use of FIPS-validated cryptography. Cryptography is implemented in accordance with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines. Related Controls: AC-2, AC-3, AC-7, AC-17, AC-18, AC-19, AU-9, AU-10, CM-11, CP-9, IA-3, IA-5,

NIST SP 800-53 Rev 5 control AC-7.2 (Purge or Wipe Mobile Device) is assessed by examining, interviewing, and testing: AC-7.2 · Purge or Wipe Mobile Device Control Statement: Purge or wipe information from [organization-defined parameter] based on [organization-defined parameter] after [organization-defined parameter] consecutive, unsuccessful device logon attempts. Supplemental Guidance: Purge or wipe information from [organization-defined parameter] based on [organization-defined parameter] after [organization-defined parameter] consecutive, unsuccessful device logon attempts. A mobile device is a computing

Control AC-19: _____ Due to the large variety of mobile devices with different characteristics and capabilities, organizational restrictions may vary for the different classes or types of such devices. Usage restrictions and specific implementation guidance for mobile devices include configuration management, device identification and authentication, implementation of mandatory protective software, scanning devices for malicious code, updating virus protection software, scanning for critical software updates and patches, conducting primary operating system (and possibly other resident software) integrity checks, and disabling unnecessary hardware. Usage restrictions and authorization to connect may vary among organizational systems. For example, the organization may authorize the connection of mobile devices to its network and impose a set of usage restrictions, while a system owner may withhold authorization for mobile device connection to specific applications or impose additional usage restrictions before allowing mobile device connections to a system. Adequate security for mobile devices goes beyond the requirements specified

in AC-19. Many safeguards for mobile devices are reflected in other controls. AC-20 addresses mobile devices that are not organization-controlled. Related Controls: AC-3, AC-4, AC-7, AC-11, AC-17, AC-18, AC-20, CA-9, CM-2, CM-6, IA-2, IA-3,

Under the FedRAMP Moderate baseline, AC-20.2 (AC-20.2 Portable Storage Devices · Restricted Use): FedRAMP Moderate Baseline · AC-20.2 · Portable Storage Devices · Restricted Use Control Statement: Restrict the use of organization-controlled portable storage devices by authorized individuals on external systems using [organization-defined parameter]. Supplemental Guidance: Restrict the use of organization-controlled portable storage devices by authorized individuals on external systems using [organization-defined parameter]. Limits on the use of organization-controlled portable storage devi

Under the FedRAMP Moderate baseline, AC-6.5 (AC-6.5 Privileged Accounts): FedRAMP Moderate Baseline · AC-6.5 · Privileged Accounts Control Statement: Restrict privileged accounts on the system to [organization-defined parameter]. Supplemental Guidance: Restrict privileged accounts on the system to [organization-defined parameter]. Privileged accounts, including super user accounts, are typically described as system administrator for various types of commercial off-the-shelf operating systems. Restricting privileged accounts to specific personnel or roles prevents da

NIST SP 800-53 Rev 5 control AC-2.11 (Usage Conditions) is assessed by examining, interviewing, and testing: AC-2.11 · Usage Conditions Control Statement: Enforce [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: Enforce [organization-defined parameter] for [organization-defined parameter]. Specifying and enforcing usage conditions helps to enforce the principle of least privilege, increase user accountability, and enable effective account monitoring. Account monitoring includes alerts generated if the account is used in violation of organizational paramete

NIST SP 800-53 Rev 5 control AC-8 (System Use Notification) summarizes the requirements for this control: AC-8 · System Use Notification Control Statement: a. Display [organization-defined parameter] to users before granting access to the system that provides privacy and security notices consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines and state that: 1. Users are accessing a U.S. Government system; 2. System usage may be monitored, recorded, and subject to audit; 3. Unauthorized use of the system is prohibited and subject to crim

NIST SP 800-53 Rev 5 control AC-3.12 (Assert and Enforce Application Access) summarizes the requirements for this control: AC-3.12 · Assert and Enforce Application Access Control Statement: (a) Require applications to assert, as part of the installation process, the access needed to the following system applications and functions: [organization-defined parameter]; (b) Provide an enforcement mechanism to prevent unauthorized access; and (c) Approve access changes after initial installation of the application. Supplemental Guidance: (a) Require applications to assert, as part of the installation process, the access

NIST SP 800-53 Rev 5 control AC-3.3 (Mandatory Access Control) is assessed by examining, interviewing, and testing: AC-3.3 · Mandatory Access Control Control Statement: Enforce [organization-defined parameter] over the set of covered subjects and objects specified in the policy, and where the policy: (a) Is uniformly enforced across the covered subjects and objects within the system; (b) Specifies that a subject that has been granted access to information is constrained from doing any of the following; (1) Passing the information to unauthorized subjects or objects; (2) Granting its privileges to other s

NIST SP 800-171 Rev 3 control 03.01.05 (03.01.05 Least Privilege) is assessed by examining the following: Assessment Objectives: - system access for users (or processes acting on behalf of users) is authorized only when necessary to accomplish assigned organizational tasks. - access to [organization-defined parameter] is authorized. - access to [organization-defined parameter] is authorized. - the privileges assigned to roles or classes of users are reviewed [organization-defined parameter] to validate the need for such privileges. - privileges are reassigned or removed, as necessary.

Under the FedRAMP Low baseline, AC-18 (AC-18 Wireless Access): FedRAMP Low Baseline · AC-18 · Wireless Access Control Statement: a. Establish configuration requirements, connection

requirements, and implementation guidance for each type of wireless access; and b. Authorize each type of wireless access to the system prior to allowing such connections. Supplemental Guidance: a. Establish configuration requirements, connection requirements, and implementation guidance for each type of wireless access; and b. Authorize each type of wireless access to the syst

NIST SP 800-53 Rev 5 control AC-3.5 (Security-relevant Information) summarizes the requirements for this control: AC-3.5 · Security-relevant Information Control Statement: Prevent access to [organization-defined parameter] except during secure, non-operable system states. Supplemental Guidance: Prevent access to [organization-defined parameter] except during secure, non-operable system states. Security-relevant information is information within systems that can potentially impact the operation of security functions or the provision of security services in a manner that could result in failure to enforce s

NIST SP 800-171 Rev 3 control 03.01.09 (03.01.09 System Use Notification) requires organizations to implement the following: 03.01.09 · System Use Notification Supplemental Guidance: System use notifications can be implemented using messages or warning banners. The messages or warning banners are displayed before individuals log in to a system that processes, stores, or transmits CUI. System use notifications are used for access via logon interfaces with human users and are not required when human interfaces do not exist. Organizations consider whether a secondary use notification is needed to access applications or For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.09.

NIST SP 800-171 Rev 3 control 03.01.08 (03.01.08 Unsuccessful Logon Attempts) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP Moderate baseline, AC-17.4 (AC-17.4 Privileged Commands and Access): FedRAMP Moderate Baseline · AC-17.4 · Privileged Commands and Access Control Statement: (a) Authorize the execution of privileged commands and access to security-relevant information via remote access only in a format that provides assessable evidence and for the following needs: [organization-defined parameter] ; and (b) Document the rationale for remote access in the security plan for the system. Supplemental Guidance: (a) Authorize the execution of privileged commands and access to security

AC-24.1 · Transmit Access Authorization Information Control Statement: Transmit [organization-defined parameter] using [organization-defined parameter] to [organization-defined parameter] that enforce access control decisions. Supplemental Guidance: Transmit [organization-defined parameter] using [organization-defined parameter] to [organization-defined parameter] that enforce access control decisions. Authorization processes and access control decisions may occur in separate parts of systems or in separate systems. In such instances, authorization information is transmitted securely (e.g., using cryptographic mechanisms) so that timely access control decisions can be enforced at the appropriate locations. To support the access control decisions, it may be necessary to transmit as part of the access authorization information supporting security and privacy attributes. This is because in distributed systems, there are various access control decisions that need to be made, and different entities make these decisions in a serial fashion, each requiring those attributes to make the decisions. Protecting access authorization information ensures that such information cannot be altered, spoofed, or compromised during transmission.

Under the FedRAMP High baseline, AC-6.9 (AC-6.9 Log Use of Privileged Functions): FedRAMP High Baseline · AC-6.9 · Log Use of Privileged Functions Control Statement: Log the execution of privileged functions. Supplemental Guidance: Log the execution of privileged functions. The misuse of privileged functions, either intentionally or unintentionally by authorized users or by unauthorized external entities that have compromised system accounts, is a serious and ongoing concern and can have significant adverse impacts on organizations. Logging and analyzing the use of privileg

AC-3.9 · Controlled Release Control Statement: Release information outside of the system only if: (a) The receiving [organization-defined parameter] provides [organization-defined parameter] ; and

(b) [organization-defined parameter] are used to validate the appropriateness of the information designated for release. Supplemental Guidance: Release information outside of the system only if:

- (a) The receiving [organization-defined parameter] provides [organization-defined parameter] ; and
- (b) [organization-defined parameter] are used to validate the appropriateness of the information designated for release. Organizations can only directly protect information when it resides within the system. Additional controls may be needed to ensure that organizational information is adequately protected once it is transmitted outside of the system. In situations where the system is unable to determine the adequacy of the protections provided by external entities, as a mitigation measure, organizations procedurally determine whether the external systems are providing adequate controls. The means used to determine the adequacy of controls provided by external systems include conducting periodic assessments (inspections/tests), establishing agreements between the organization and its counterpart organizations, or some other process. The means used by external entities to protect the information received need not be the same as those used by the organization, but the means employed are sufficient to provide consistent adjudication of the security and privacy policy to protect the information and individuals' privacy. Controlled release of information requires systems to implement technical or procedural means to validate the information prior to releasing it to external systems. For example, if the system passes information to a system controlled by another organization, technical means are employed to validate that the security and privacy attributes associated with the exported information are appropriate for the receiving system. Alternatively, if the system passes information to a printer in organization-controlled space, procedural means can be employed to ensure that only authorized individuals gain access to the printer.

NIST SP 800-171 Rev 3 control 03.01.04 (03.01.04 Separation of Duties) falls under the Access Control family. Control Statement: SR-03.01.04.a Identify the duties of individuals requiring separation. SR-03.01.04.b Define system access authorizations to support separation of duties. Supplemental Guidance: Separation of duties addresses the potential for abuse of authorized privileges and reduces the risk of malevolent activity without collusion. Separation of duties includes dividing mission functions and support functions among different individuals or roles, conducting system support functions with different individuals or roles (e.g., quality assurance, configuration management, network security, system management, assessments, and programming), and ensuring that personn

NIST SP 800-171 Rev 3 control 03.01.10 (03.01.10 Device Lock) is assessed by examining the following: Assessment Objectives: - access to the system is prevented by [organization-defined parameter]. - information previously visible on the display is concealed via device lock with a publicly viewable image. - the device lock is retained until the user reestablishes access using established identification and authentication procedures.

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: AC-06(02), AC-06(05) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.06.a [Assignment: organization-defined personnel or roles] only defined and authorized personnel or administrative roles Access Control 3.1.8 Invalid Logon Attempts a. Enforce a limit of [Assignment: organization-defined number] (03.01.08.a.01) consecutive invalid logon attempts by a user during a [Assignment: organization-defined time period] (03.01.08.a.02). b. Automatically [Selection (one or more): lock the account or node for an [Assignment: organization-defined time period]; lock the account or node until released by an administrator; delay next logon prompt; notify system administrator; take other action] (03.01.08.b) when the maximum number of unsuccessful attempts is

Access Control 3.1.20 Use of External Systems a. Prohibit the use of external systems unless the systems are specifically authorized. b. Establish the following security requirements to be satisfied on external systems prior to allowing use of or access to those systems by authorized individuals: [Assignment: organization-defined security requirements] (03.01.20.b). c. Permit authorized individuals to use external systems to access the organizational system or to process, store, or transmit CUI only after: 1. Verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied, and 2. Retaining approved system connection or processing agreements with the organizational entities hosting the external systems. d. Restrict the use of organization-controlled portable storage devices by authorized individuals on external systems. Related Controls: AC-20, AC-20(01), AC-20(02) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.20.b [Assignment:

organization- defined security requirements] Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800- 47 as a guide for establishing information exchanges between organizations.

NIST SP 800-53 Rev 5 control AC-17.2 (Protection of Confidentiality and Integrity Using Encryption) is assessed by examining, interviewing, and testing: AC-17.2 · Protection of Confidentiality and Integrity Using Encryption Control Statement: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Supplemental Guidance: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Virtual private networks can be used to protect the confidentiality and integrity of remote access sessions. Transport Layer Security (TLS) is an example of a cryptographi

Under the FedRAMP High baseline, AC-2.9 (AC-2.9 Restrictions on Use of Shared and Group Accounts): FedRAMP High Baseline · AC-2.9 · Restrictions on Use of Shared and Group Accounts Control Statement: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Supplemental Guidance: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Before permitting the use of shared or group accounts, organizations consider the increased risk due to the lack of accountability with such accounts. Assessment Objectives: Only permit t

Access Control 3.1.6 Privileged Account Management a. Restrict privileged accounts on the system to [Assignment: organization-defined personnel or roles] (03.01.06.a). b. Require that users (or roles) with privileged accounts use non-privileged accounts when accessing non-security functions or non-security information. Related Controls: AC-06(02), AC-06(05) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.06.a [Assignment: organization-defined personnel or roles] only defined and authorized personnel or administrative roles

NIST SP 800-53 Rev 5 control AC-4.1 (Object Security and Privacy Attributes) summarizes the requirements for this control: AC-4.1 · Object Security and Privacy Attributes Control Statement: Use [organization-defined parameter] associated with [organization-defined parameter] to enforce [organization-defined parameter] as a basis for flow control decisions. Supplemental Guidance: Use [organization-defined parameter] associated with [organization-defined parameter] to enforce [organization-defined parameter] as a basis for flow control decisions. Information flow enforcement mechanisms compare security and privacy a

NIST SP 800-171 Rev 3 control 03.01.18 (03.01.18 Access Control for Mobile Devices) falls under the Access Control family. Control Statement: SR-03.01.18.a Establish usage restrictions, configuration requirements, and connection requirements for mobile devices. SR-03.01.18.b Authorize the connection of mobile devices to the system. SR-03.01.18.c Implement full-device or container-based encryption to protect the confidentiality of CUI on mobile devices. Supplemental Guidance: A mobile device is a computing device with a small form factor such that it can be carried by a single individual; is designed to operate without a physical connection; possesses local, non-removable, or removable data storage; and includes a self-contained power source. Mobile device functionality may include on-board sensors that allow the device to capture information, voice communication capabilities, and/or built-in features for synchronizing local data with remote lo

Implementing 03.01.22 (03.01.22 Publicly Accessible Content) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.01.22 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document

in their SSP which components of 03.01.22 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control AC-4.28 (Linear Filter Pipelines): AC-4.28 · Linear Filter Pipelines
Control Statement: When transferring information between different security domains, implement a linear content filter pipeline that is enforced with discretionary and mandatory access controls.
Supplemental Guidance: When transferring information between different security domains, implement a linear content filter pipeline that is enforced with discretionary a

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Access Control 3.1.20 Use of External Systems a. Prohibit the use of external systems unless the systems are specifically authorized. b. Establish the following security requirements to be satisfied on external systems prior to allowing use of or access to those systems by authorized individuals: [Assignment: organization-defined security requirements] (03.01.20.b). c. Permit authorized individuals to use external systems to access the organizational system or to process, store, or transmit CUI only after: 1. Verifying that the security requirements on the external systems as specified in the organization-s system security plans have been satisfied, and 2. Retaining approved system connection or processing agreements with the organizational entities hosting the external systems.

NIST SP 800-53 Rev 5 control AC-16.10 (Attribute Configuration by Authorized Individuals) summarizes the requirements for this control: AC-16.10 · Attribute Configuration by Authorized Individuals
Control Statement: Provide authorized individuals the capability to define or change the type and value of security and privacy attributes available for association with subjects and objects.
Supplemental Guidance: Provide authorized individuals the capability to define or change the type and value of security and privacy attributes available for association with subjects and objects.
The content or assigned values of security and pr

NIST SP 800-171 Rev 3 control 03.01.10 (03.01.10 Device Lock) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP High baseline, AC-2.13 (AC-2.13 Disable Accounts for High-risk Individuals): FedRAMP High Baseline · AC-2.13 · Disable Accounts for High-risk Individuals Control Statement: Disable accounts of individuals within [organization-defined parameter] of discovery of [organization-defined parameter]. Supplemental Guidance: Disable accounts of individuals within [organization-defined parameter] of discovery of [organization-defined parameter]. Users who pose a significant security and/or privacy risk include individuals for whom reliable evidence indicates either the intention

NIST SP 800-171 Rev 3 control 03.01.22 (03.01.22 Publicly Accessible Content) requires organizations to implement the following: Control Statement: SR-03.01.22.a Train authorized individuals to ensure that publicly accessible information does not contain CUI. SR-03.01.22.b Review the content on publicly accessible systems for CUI and remove such information, if discovered. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.22.

NIST SP 800-171 Rev 3 control 03.01.06 (03.01.06 Least Privilege · Privileged Accounts) is assessed by examining the following: Assessment Objectives: - privileged accounts on the system are restricted to [organization-defined parameter]. - users (or roles) with privileged accounts are required to use non-privileged accounts when accessing non-security functions or non-security information.

NIST SP 800-53 Rev 5 control AC-4.13 (Decomposition into Policy-relevant Subcomponents) is assessed by examining, interviewing, and testing: AC-4.13 · Decomposition into Policy-relevant Subcomponents
Control Statement: When transferring information between different security domains, decompose information into [organization-defined parameter] for submission to policy enforcement mechanisms.
Supplemental Guidance: When transferring information between different security domains, decompose information into [organization-defined parameter] for submission to policy enforcement mechanisms.

Decomposing information into policy-relevant su

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-03(07) 03.0 1.12E Physical or Logical Separation of CUI Flows Separate CUI flows logically or physically using [Assignment: organization-defined mechanisms and/or techniques]. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 DISCUSSION 647

From the NIST SP 800-172 Rev 3 Final Public Draft: Source Control: AC-04(06) 03.0 1.14E Security Policy Filters a. Enforce information flow control using [Assignment: organization-defined security policy filters] as a basis for flow control decisions for [Assignment: organization-defined information flows]. b. [Selection (one or more): Block; Strip; Modify; Quarantine] data after a filter processing failure in accordance with [Assignment: organization-defined security policy]. DISCUSSION Security policy filters for data structures check for maximum file lengths, maximum field sizes, and data/file types for structured and unstructured data. Security policy filters for data content check for specific words, enumerated values or data value ranges, and hidden content. Structured data permits the interpretation of data content by

NIST SP 800-53 Rev 5 control AC-4.13 (Decomposition into Policy-relevant Subcomponents) summarizes the requirements for this control: AC-4.13 · Decomposition into Policy-relevant Subcomponents Control Statement: When transferring information between different security domains, decompose information into [organization-defined parameter] for submission to policy enforcement mechanisms. Supplemental Guidance: When transferring information between different security domains, decompose information into [organization-defined parameter] for submission to policy enforcement mechanisms. Decomposing information into policy-relevant su

NIST SP 800-53 Rev 5 control AC-17.10 (Authenticate Remote Commands) summarizes the requirements for this control: AC-17.10 · Authenticate Remote Commands Control Statement: Implement [organization-defined parameter] to authenticate [organization-defined parameter]. Supplemental Guidance: Implement [organization-defined parameter] to authenticate [organization-defined parameter]. Authenticating remote commands protects against unauthorized commands and the replay of authorized commands. The ability to authenticate remote commands is important for remote systems for which loss, malfunction, misdirection, or

Summary of Enhanced Security Requirements 3120 This appendix provides a consolidated list of the enhanced security requirements in Sec. 3. The type of enhanced security requirement is indicated in the last column of Table 2. · A designation of ·E· indicates that the security requirement enhances a requirement in SP 800-171 [12] and includes AP 800-171 requirement. · A designation of ·T· indicates that the security requirement is sourced to a control tailored out of the SP 800-53B [13] moderate baseline in SP 800-171 and includes the SP 800-53 control. · A designation of ·S· indicates that the security requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. It includes the source control from SP 800-53. Table 2. Enhanced security requirements

REQUIREMENT	NUMBER	ENHANCED SECURITY REQUIREMENT	REQUIREMENT TYPE
Access Control	03.01.01E	Dual Authorization	E
03.01.02	03.01.02E	Non-Organizationally Owned Systems - Restricted Use	E
03.01.03E	Withdrawn	03.01.04E	Concurrent Session Control
S	SP 800-53, AC-10	03.01.05E	Remote Access Monitoring and Control
E	03.01.02	03.01.06E	Protection of Remote Access Mechanism
Information	E	03.01.02	03.01.07E
Automated Audit Actions for Account Management	E	03.01.01	03.01.08E
Account Monitoring for Atypical Usage	E	03.01.01	03.01.09E
Attribute-Based Access Control	E	03.01.02	03.01.10E
Object Security Attributes	E	03.01.03	03.01.11E
Role-Based Access Control	E	03.01.02	03.01.12E
Physical or Logical Separation of Information Flows	E	03.01.03	03.01.13E
Metadata	E	03.01.03	03.01.14E
Security Policy Filters	E	03.01.03	03.01.15E
Data Type Identifiers	E	03.01.03	03.01.16E
Decomposition into Policy-Relevant Subcomponents	E	03.01.03	03.01.17E
Detection of Unsanctioned CUI	E	03.01.03	Awareness and Training
03.02.01E	Advanced Literacy and Awareness Training	E	03.02.01
03.02.01	03.02.02E	Literacy and Awareness Training Practical Exercises	E
03.02.01	03.02.03E	Literacy and Awareness Training Feedback	S
SP 800-53, AT-06			

Under the FedRAMP Moderate baseline, AC-1 (AC-1 Policy and Procedures): FedRAMP Moderate Baseline · AC-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] access control policy that:

2. Procedures to facilitate the implementation of the access control policy and the associated access controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the access control policy and procedures; and c. Review

Under the FedRAMP High baseline, AC-18.3 (AC-18.3 Disable Wireless Networking): FedRAMP High Baseline · AC-18.3 · Disable Wireless Networking Control Statement: Disable, when not intended for use, wireless networking capabilities embedded within system components prior to issuance and deployment. Supplemental Guidance: Disable, when not intended for use, wireless networking capabilities embedded within system components prior to issuance and deployment. Wireless networking capabilities that are embedded within system components represent a significant potential vulnerability

From the NIST SP 800-172 Rev 3 Final Public Draft: Organizations can create rules based on specified attributes and the authorizations 579 (i.e., privileges) to perform needed operations on the systems associated with organization-defined attributes and rules. When users are assigned to attributes defined in attribute-based access control policies or rules, they can be provisioned to a system with the appropriate privileges or dynamically granted access to a protected resource. Attribute-based access control can be implemented as either a mandatory or discretionary form of access control. This requirement enhances SP 800-171 requirement 03.01.02. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-03(13) 03.0 1.10E Object Security Attributes Use [Assignment: organization-defined]

NIST SP 800-53 Rev 5 control AC-2.13 (Disable Accounts for High-risk Individuals) summarizes the requirements for this control: AC-2.13 · Disable Accounts for High-risk Individuals Control Statement: Disable accounts of individuals within [organization-defined parameter] of discovery of [organization-defined parameter]. Supplemental Guidance: Disable accounts of individuals within [organization-defined parameter] of discovery of [organization-defined parameter]. Users who pose a significant security and/or privacy risk include individuals for whom reliable evidence indicates either the intention to use authorized access

NIST SP 800-53 Rev 5 control AC-6.2 (Non-privileged Access for Nonsecurity Functions) is defined as follows: AC-6.2 · Non-privileged Access for Nonsecurity Functions Control Statement: Require that users of system accounts (or roles) with access to [organization-defined parameter] use non-privileged accounts or roles, when accessing nonsecurity functions. Supplemental Guidance: Require that users of system accounts (or roles) with access to [organization-defined parameter] use non-privileged accounts or roles, when accessing nonsecurity functions. Requiring the use of non-privileged accounts when accessing nonsecurity functions limits exposure when operating from within privileged accounts or roles

NIST SP 800-53 Rev 5 control AC-4.27 (Redundant/Independent Filtering Mechanisms) summarizes the requirements for this control: AC-4.27 · Redundant/Independent Filtering Mechanisms Control Statement: When transferring information between different security domains, implement content filtering solutions that provide redundant and independent filtering mechanisms for each data type. Supplemental Guidance: When transferring information between different security domains, implement content filtering solutions that provide redundant and independent filtering mechanisms for each data type. Content filtering is the process of

AC-6.4 · Separate Processing Domains Control Statement: Provide separate processing domains to enable finer-grained allocation of user privileges. Supplemental Guidance: Provide separate processing domains to enable finer-grained allocation of user privileges. Providing separate processing domains for finer-grained allocation of user privileges includes using virtualization techniques to permit additional user privileges within a virtual machine while restricting privileges to other virtual machines or to the underlying physical machine, implementing separate physical domains, and employing hardware or software domain separation mechanisms.

NIST SP 800-171 Rev 3 control 03.01.18 (03.01.18 Access Control for Mobile Devices) requires organizations to implement the following: Control Statement: SR-03.01.18.a Establish usage restrictions, configuration requirements, and connection requirements for mobile devices. SR-03.01.18.b Authorize the connection of mobile devices to the system. SR-03.01.18.c Implement full-device or container-based encryption to protect the confidentiality of CUI on mobile devices. For practical implementation, organizations should document their approach in their System Security

Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.18.

NIST SP 800-53 Rev 5 control AC-4.10 (Enable and Disable Security or Privacy Policy Filters) summarizes the requirements for this control: AC-4.10 · Enable and Disable Security or Privacy Policy Filters Control Statement: Provide the capability for privileged administrators to enable and disable [organization-defined parameter] under the following conditions: [organization-defined parameter]. Supplemental Guidance: Provide the capability for privileged administrators to enable and disable [organization-defined parameter] under the following conditions: [organization-defined parameter]. For example, as allowed by the system author

NIST SP 800-53 Rev 5 control AC-3.8 (Revocation of Access Authorizations) is assessed by examining, interviewing, and testing: AC-3.8 · Revocation of Access Authorizations Control Statement: Enforce the revocation of access authorizations resulting from changes to the security attributes of subjects and objects based on [organization-defined parameter]. Supplemental Guidance: Enforce the revocation of access authorizations resulting from changes to the security attributes of subjects and objects based on [organization-defined parameter]. Revocation of access rules may differ based on the types of access revoked. For e

AC-16.9 · Attribute Reassignment · Regrading Mechanisms Control Statement: Change security and privacy attributes associated with information only via regrading mechanisms validated using [organization-defined parameter]. Supplemental Guidance: Change security and privacy attributes associated with information only via regrading mechanisms validated using [organization-defined parameter]. A regrading mechanism is a trusted process authorized to re-classify and re-label data in accordance with a defined policy exception. Validated regrading mechanisms are used by organizations to provide the requisite levels of assurance for attribute reassignment activities. The validation is facilitated by ensuring that regrading mechanisms are single purpose and of limited function. Since security and privacy attribute changes can directly affect policy enforcement actions, implementing trustworthy regrading mechanisms is necessary to help ensure that such mechanisms perform in a consistent and correct mode of operation.

AC-6 · Least Privilege Control Statement: Employ the principle of least privilege, allowing only authorized accesses for users (or processes acting on behalf of users) that are necessary to accomplish assigned organizational tasks. Supplemental Guidance: Employ the principle of least privilege, allowing only authorized accesses for users (or processes acting on behalf of users) that are necessary to accomplish assigned organizational tasks. Organizations employ least privilege for specific duties and systems. The principle of least privilege is also applied to system processes, ensuring that the processes have access to systems and operate at privilege levels no higher than necessary to accomplish organizational missions or business functions. Organizations consider the creation of additional processes, roles, and accounts as necessary to achieve least privilege. Organizations apply least privilege to the development, implementation, and operation of organizational systems.

NIST SP 800-53 Rev 5 control AC-4.30 (Filter Mechanisms Using Multiple Processes) is defined as follows: AC-4.30 · Filter Mechanisms Using Multiple Processes Control Statement: When transferring information between different security domains, implement content filtering mechanisms using multiple processes. Supplemental Guidance: When transferring information between different security domains, implement content filtering mechanisms using multiple processes. The use of multiple processes to implement content filtering mechanisms reduces the likelihood of a single point of failure.

NIST SP 800-53 Rev 5 control AC-17.4 (Privileged Commands and Access): AC-17.4 · Privileged Commands and Access Control Statement: (a) Authorize the execution of privileged commands and access to security-relevant information via remote access only in a format that provides assessable evidence and for the following needs: [organization-defined parameter] ; and (b) Document the rationale for remote access in the security plan for the system. Supplemental Guidance: (

NIST SP 800-171 Rev 3 control 03.01.22 (03.01.22 Publicly Accessible Content) is assessed by examining the following: Assessment Objectives: - authorized individuals are trained to ensure that publicly accessible information does not contain CUI. - the content on publicly accessible systems

is reviewed for CUI. - CUI is removed from publicly accessible systems, if discovered.

NIST SP 800-53 Rev 5 control AC-9 (Previous Logon Notification) is assessed by examining, interviewing, and testing: AC-9 · Previous Logon Notification Control Statement: Notify the user, upon successful logon to the system, of the date and time of the last logon. Supplemental Guidance: Notify the user, upon successful logon to the system, of the date and time of the last logon. Previous logon notification is applicable to system access via human user interfaces and access to systems that occurs in other types of architectures. Information about the last successful logon allows the user to recognize if the d

NIST SP 800-53 Rev 5 control AC-2.6 (Dynamic Privilege Management) is assessed by examining, interviewing, and testing: AC-2.6 · Dynamic Privilege Management Control Statement: Implement [organization-defined parameter]. Supplemental Guidance: Implement [organization-defined parameter]. In contrast to access control approaches that employ static accounts and predefined user privileges, dynamic access control approaches rely on runtime access control decisions facilitated by dynamic privilege management, such as attribute-based access control. While user identities remain relatively constant over time, user priv

NIST SP 800-53 Rev 5 control AC-3.9 (Controlled Release) is assessed by examining, interviewing, and testing: AC-3.9 · Controlled Release Control Statement: Release information outside of the system only if: (a) The receiving [organization-defined parameter] provides [organization-defined parameter] ; and (b) [organization-defined parameter] are used to validate the appropriateness of the information designated for release. Supplemental Guidance: Release information outside of the system only if: (a) The receiving [organization-defined parameter] provides [organization-defined parameter] ; and (b) [or

Implementing 03.01.16 (03.01.16 Wireless Access) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.01.16 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.01.16 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-171 Rev 3 control 03.01.07 (03.01.07 Least Privilege · Privileged Functions) is assessed by examining the following: Assessment Objectives: - the execution of privileged functions is logged. - non-privileged users are prevented from executing privileged functions.

NIST SP 800-53 Rev 5 control AC-17.6 (Protection of Mechanism Information) is assessed by examining, interviewing, and testing: AC-17.6 · Protection of Mechanism Information Control Statement: Protect information about remote access mechanisms from unauthorized use and disclosure. Supplemental Guidance: Protect information about remote access mechanisms from unauthorized use and disclosure. Remote access to organizational information by non-organizational entities can increase the risk of unauthorized use and disclosure about remote access mechanisms. The organization considers including remote access requirements in t

Under the FedRAMP High baseline, AC-2.1 (AC-2.1 Automated System Account Management): FedRAMP High Baseline · AC-2.1 · Automated System Account Management Control Statement: Support the management of system accounts using [organization-defined parameter]. Supplemental Guidance: Support the management of system accounts using [organization-defined parameter]. Automated system account management includes using automated mechanisms to create, enable, modify, disable, and remove accounts; notify account managers when an account is created, enabled, modified, disabled, or removed, o

Under the FedRAMP Moderate baseline, AC-4.21 (AC-4.21 Physical or Logical Separation of Information

Flows): FedRAMP Moderate Baseline · AC-4.21 · Physical or Logical Separation of Information Flows
Control Statement: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Supplemental Guidance: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Enforcing the separation of information flows associated with defined types of data can en

Under the FedRAMP Moderate baseline, AC-14 (AC-14 Permitted Actions Without Identification or Authentication): FedRAMP Moderate Baseline · AC-14 · Permitted Actions Without Identification or Authentication Control Statement: a. Identify [organization-defined parameter] that can be performed on the system without identification or authentication consistent with organizational mission and business functions; and b. Document and provide supporting rationale in the security plan for the system, user actions not requiring identification or authentication. Supplemental Guidance: a. Identify [organization-def

NIST SP 800-53 Rev 5 control AC-9.2 (Successful and Unsuccessful Logons) is assessed by examining, interviewing, and testing: AC-9.2 · Successful and Unsuccessful Logons Control Statement: Notify the user, upon successful logon, of the number of [organization-defined parameter] during [organization-defined parameter]. Supplemental Guidance: Notify the user, upon successful logon, of the number of [organization-defined parameter] during [organization-defined parameter]. Information about the number of successful and unsuccessful logon attempts within a specified time period allows the user to recognize if the number a

NIST SP 800-171 Rev 3 control 03.01.12 (03.01.12 Remote Access) is assessed by examining the following: Assessment Objectives: - types of allowable remote system access are defined. - usage restrictions are established for each type of allowable remote system access. - configuration requirements are established for each type of allowable remote system access. - connection requirements are established for each type of allowable remote system access. - each type of remote system access is authorized prior to establishing such connections. - remote access to the system is routed through authorized access control points. - remote access to the system is routed through managed access control points.

NIST SP 800-53 Rev 5 control AC-20.3 (Non-organizationally Owned Systems · Restricted Use) is assessed by examining, interviewing, and testing: AC-20.3 · Non-organizationally Owned Systems · Restricted Use Control Statement: Restrict the use of non-organizationally owned systems or system components to process, store, or transmit organizational information using [organization-defined parameter]. Supplemental Guidance: Restrict the use of non-organizationally owned systems or system components to process, store, or transmit organizational information using [organization-defined parameter]. Non-organizationally owned systems or system c

NIST SP 800-53 Rev 5 control AC-4.28 (Linear Filter Pipelines) is assessed by examining, interviewing, and testing: AC-4.28 · Linear Filter Pipelines Control Statement: When transferring information between different security domains, implement a linear content filter pipeline that is enforced with discretionary and mandatory access controls. Supplemental Guidance: When transferring information between different security domains, implement a linear content filter pipeline that is enforced with discretionary and mandatory access controls. Content filtering is the process of inspecting information as it trave

Implementing 03.01.06 (03.01.06 Least Privilege · Privileged Accounts) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.01.06 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.01.06 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA ADVERSARY EFFECTS
Preclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-04(13) NIST SP 800-172r3 fpd
(Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 03.01.17E
Detection of Unsanctioned CUI 740

NIST SP 800-53 Rev 5 control AC-14 (Permitted Actions Without Identification or Authentication) summarizes the requirements for this control: AC-14 · Permitted Actions Without Identification or Authentication Control Statement: a. Identify [organization-defined parameter] that can be performed on the system without identification or authentication consistent with organizational mission and business functions; and b. Document and provide supporting rationale in the security plan for the system, user actions not requiring identification or authentication. Supplemental Guidance: a. Identify [organization-defined parameter] that can be

NIST SP 800-53 Rev 5 control AC-3.3 (Mandatory Access Control) summarizes the requirements for this control: AC-3.3 · Mandatory Access Control Control Statement: Enforce [organization-defined parameter] over the set of covered subjects and objects specified in the policy, and where the policy: (a) Is uniformly enforced across the covered subjects and objects within the system; (b) Specifies that a subject that has been granted access to information is constrained from doing any of the following; (1) Passing the information to unauthorized subjects or objects; (2) Granting its privileges to other s

NIST SP 800-53 Rev 5 control AC-18.5 (Antennas and Transmission Power Levels) summarizes the requirements for this control: AC-18.5 · Antennas and Transmission Power Levels Control Statement: Select radio antennas and calibrate transmission power levels to reduce the probability that signals from wireless access points can be received outside of organization-controlled boundaries. Supplemental Guidance: Select radio antennas and calibrate transmission power levels to reduce the probability that signals from wireless access points can be received outside of organization-controlled boundaries. Actions that may be tak

NIST SP 800-53 Rev 5 control AC-20.1 (Limits on Authorized Use): AC-20.1 · Limits on Authorized Use Control Statement: Permit authorized individuals to use an external system to access the system or to process, store, or transmit organization-controlled information only after: (a) Verification of the implementation of controls on the external system as specified in the organization-s security and privacy policies and security and privacy plans; or (b) Retentio

NIST SP 800-53 Rev 5 control AC-2.3 (Disable Accounts) is assessed by examining, interviewing, and testing: AC-2.3 · Disable Accounts Control Statement: Disable accounts within [organization-defined parameter] when the accounts: (a) Have expired; (b) Are no longer associated with a user or individual; (c) Are in violation of organizational policy; or (d) Have been inactive for [organization-defined parameter]. Supplemental Guidance: Disable accounts within [organization-defined parameter] when the accounts: (a) Have expired; (b) Are no longer associated with a user or individual; (c) Are in violatio

NIST SP 800-171 Rev 3 control 03.01.18 (03.01.18 Access Control for Mobile Devices) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

03.01.16 · Wireless Access Control Statement: SR-03.01.16.a Establish usage restrictions, configuration requirements, and connection requirements for each type of wireless access to the system. SR-03.01.16.b Authorize each type of wireless access to the system prior to establishing such connections. SR-03.01.16.c Disable, when not intended for use, wireless networking capabilities prior to issuance and deployment. SR-03.01.16.d Protect wireless access to the system using authentication and encryption. Supplemental Guidance: Wireless networking capabilities represent a significant potential vulnerability that can be exploited by adversaries. Establishing usage restrictions, configuration requirements, and connection requirements for wireless access to the system provides criteria to support access authorization decisions. These restrictions and requirements reduce susceptibility to unauthorized system access through wireless technologies.

Wireless networks use authentication protocols that provide credential protection and mutual authentication. Organizations authenticate individuals and devices to protect wireless access to the system. Special attention is given to the variety of devices with potential wireless access to the system, including small form factor mobile devices (e.g., smart phones, tablets, smart watches). Wireless networking capabilities that are embedded within system components represent a potential vulnerability that can be exploited by adversaries. Strong authentication of users and devices, strong encryption, and disabling wireless capabilities that are not needed for essential mission or business functions can reduce susceptibility to threats by adversaries involving wireless technologies. Assessment Objectives: - each type of wireless access to the system is defined. - usage restrictions are established for each type of wireless access to the system. - configuration requirements are established for each type of wireless access to the system. - connection requirements are established for each type of wireless access to the system. - each type of wireless access to the system is authorized prior to establishing such connections. - wireless networking capabilities not intended for use are disabled prior to issuance and deployment. - wireless access to the system is protected using authentication. - wireless access to the system is protected using encryption.

FedRAMP Moderate Baseline · AC-17.2 · Protection of Confidentiality and Integrity Using Encryption Control Statement: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Supplemental Guidance: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Virtual private networks can be used to protect the confidentiality and integrity of remote access sessions. Transport Layer Security (TLS) is an example of a cryptographic protocol that provides end-to-end communications security over networks and is used for Internet communications and online transactions. Assessment Objectives: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions.

NIST SP 800-53 Rev 5 control AC-9.4 (Additional Logon Information) summarizes the requirements for this control: AC-9.4 · Additional Logon Information Control Statement: Notify the user, upon successful logon, of the following additional information: [organization-defined parameter]. Supplemental Guidance: Notify the user, upon successful logon, of the following additional information: [organization-defined parameter]. Organizations can specify additional information to be provided to users upon logon, including the location of the last logon. User location is defined as information that can be determine

NIST SP 800-53 Rev 5 control AC-2.6 (Dynamic Privilege Management) summarizes the requirements for this control: AC-2.6 · Dynamic Privilege Management Control Statement: Implement [organization-defined parameter]. Supplemental Guidance: Implement [organization-defined parameter]. In contrast to access control approaches that employ static accounts and predefined user privileges, dynamic access control approaches rely on runtime access control decisions facilitated by dynamic privilege management, such as attribute-based access control. While user identities remain relatively constant over time, user priv

NIST SP 800-171 Rev 3 control 03.01.20 (03.01.20 Use of External Systems) is assessed by examining the following: Assessment Objectives: - the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: [organization-defined parameter]. - the use of external systems is prohibited unless the systems are specifically authorized. - authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization-s system security plans have bee

NIST SP 800-53 Rev 5 control AC-17.3 (Managed Access Control Points) is assessed by examining, interviewing, and testing: AC-17.3 · Managed Access Control Points Control Statement: Route remote accesses through authorized and managed network access control points. Supplemental Guidance: Route remote accesses through authorized and managed network access control points. Organizations consider the Trusted Internet Connections (TIC) initiative [DHS TIC](#4f42ee6e-86cc-403b-a51f-76c2b4f81b54) requirements for external network connections since limiting the number of access control points for remote access reduces att

NIST SP 800-53 Rev 5 control AC-4.4 (Flow Control of Encrypted Information) is defined as follows:
AC-4.4 · Flow Control of Encrypted Information Control Statement: Prevent encrypted information from bypassing [organization-defined parameter] by [organization-defined parameter]. Supplemental Guidance: Prevent encrypted information from bypassing [organization-defined parameter] by [organization-defined parameter]. Flow control mechanisms include content checking, security policy filters, and data type identifiers. The term encryption is extended to cover encoded data not recognized by filtering mechanisms.

NIST SP 800-53 Rev 5 control AC-4.1 (Object Security and Privacy Attributes) is assessed by examining, interviewing, and testing: AC-4.1 · Object Security and Privacy Attributes Control Statement: Use [organization-defined parameter] associated with [organization-defined parameter] to enforce [organization-defined parameter] as a basis for flow control decisions. Supplemental Guidance: Use [organization-defined parameter] associated with [organization-defined parameter] to enforce [organization-defined parameter] as a basis for flow control decisions. Information flow enforcement mechanisms compare security and privacy a

NIST SP 800-171 Rev 3 control 03.01.18 (03.01.18 Access Control for Mobile Devices) is assessed by examining the following: Assessment Objectives: - usage restrictions are established for mobile devices. - configuration requirements are established for mobile devices. - connection requirements are established for mobile devices. - the connection of mobile devices to the system is authorized. - full-device or container-based encryption is implemented to protect the confidentiality of CUI on mobile devices.

Implementing 03.01.12 (03.01.12 Remote Access) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.01.12 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.01.12 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control AC-6.2 (Non-privileged Access for Nonsecurity Functions) is assessed by examining, interviewing, and testing: AC-6.2 · Non-privileged Access for Nonsecurity Functions Control Statement: Require that users of system accounts (or roles) with access to [organization-defined parameter] use non-privileged accounts or roles, when accessing nonsecurity functions. Supplemental Guidance: Require that users of system accounts (or roles) with access to [organization-defined parameter] use non-privileged accounts or roles, when accessing nonsecurity functions. Requiring the use of non-privileged accounts when acc

Under the FedRAMP High baseline, AC-11.1 (AC-11.1 Pattern-hiding Displays): FedRAMP High Baseline · AC-11.1 · Pattern-hiding Displays Control Statement: Conceal, via the device lock, information previously visible on the display with a publicly viewable image. Supplemental Guidance: Conceal, via the device lock, information previously visible on the display with a publicly viewable image. The pattern-hiding display can include static or dynamic images, such as patterns used with screen savers, photographic images, solid colors, clock, battery life indicator, or a blan

NIST SP 800-171 Rev 3 control 03.01.09 (03.01.09 System Use Notification) is assessed by examining the following: Assessment Objectives: - a system use notification message with privacy and security notices consistent with applicable CUI rules is displayed before granting access to the system.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY 518 P RA, DLO ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-17(01) 03.0 1.06E Protection of Remote Access Mechanism Information Protect information about remote access mechanisms from unauthorized use and disclosure. DISCUSSION Access to organizational information about remote access mechanisms by non- organizational entities can increase the risk of unauthorized use

and disclosure. The organization considers including remote access requirements in the information exchange agreements with other organizations, as applicable. Remote access requirements can also be included in rules of behavior and access agreements. This requirement enhances SP 800-171 requirement 03.01.12. PROTECTION STRATEGY PRA ADVERSARY EFFECTS P

NIST SP 800-53 Rev 5 control AC-5 (Separation of Duties) summarizes the requirements for this control: AC-5 · Separation of Duties Control Statement: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Supplemental Guidance: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Separation of duties addresses the potential for abuse of authorized privileges and helps to reduce the risk of malevolent activity without collusion. Separ

NIST SP 800-171 Rev 3 control 03.01.07 (03.01.07 Least Privilege · Privileged Functions) is assessed by examining the following: Assessment Objectives: - the execution of privileged functions is logged. - non-privileged users are prevented from executing privileged functions.

NIST SP 800-53 Rev 5 control AC-24 (Access Control Decisions) summarizes the requirements for this control: AC-24 · Access Control Decisions Control Statement: [organization-defined parameter] to ensure [organization-defined parameter] are applied to each access request prior to access enforcement. Supplemental Guidance: [organization-defined parameter] to ensure [organization-defined parameter] are applied to each access request prior to access enforcement. Access control decisions (also known as authorization decisions) occur when authorization information is applied to specific accesses. In contr

NIST SP 800-171 Rev 3 control 03.01.08 (03.01.08 Unsuccessful Logon Attempts) is assessed by examining the following: Assessment Objectives: - a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during [organization-defined parameter] is enforced. - [organization-defined parameter] when the maximum number of unsuccessful attempts is exceeded.

NIST SP 800-53 Rev 5 control AC-20.1 (Limits on Authorized Use) is assessed by examining, interviewing, and testing: AC-20.1 · Limits on Authorized Use Control Statement: Permit authorized individuals to use an external system to access the system or to process, store, or transmit organization-controlled information only after: (a) Verification of the implementation of controls on the external system as specified in the organization-s security and privacy policies and security and privacy plans; or (b) Retention of approved system connection or processing agreements with the organizational entity hosting the

NIST SP 800-171 Rev 3 control 03.01.09 (03.01.09 System Use Notification) is assessed by examining the following: Assessment Objectives: - a system use notification message with privacy and security notices consistent with applicable CUI rules is displayed before granting access to the system.

NIST SP 800-53 Rev 5 control AC-2.13 (Disable Accounts for High-risk Individuals): AC-2.13 · Disable Accounts for High-risk Individuals Control Statement: Disable accounts of individuals within [organization-defined parameter] of discovery of [organization-defined parameter]. Supplemental Guidance: Disable accounts of individuals within [organization-defined parameter] of discovery of [organization-defined parameter]. Users who pose a significant security and/or privacy risk i

NIST SP 800-53 Rev 5 control AC-4.21 (Physical or Logical Separation of Information Flows) summarizes the requirements for this control: AC-4.21 · Physical or Logical Separation of Information Flows Control Statement: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Supplemental Guidance: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Enforcing the separation of information flows associated with defined types of data can enhance protection by ensuring

NIST SP 800-53 Rev 5 control AC-21 (Information Sharing) summarizes the requirements for this control: AC-21 · Information Sharing Control Statement: a. Enable authorized users to determine whether access authorizations assigned to a sharing partner match the information-s access and use

restrictions for [organization-defined parameter] ; and b. Employ [organization-defined parameter] to assist users in making information sharing and collaboration decisions. Supplemental Guidance: a. Enable authorized users to determine whether access authorizations assigned to a sharing partner match the infor

NIST SP 800-171 Rev 3 control 03.01.01 (03.01.01 Account Management) is assessed by examining the following: Assessment Objectives: - system accounts are created in accordance with organizational policy, procedures, prerequisites, and criteria. - system accounts are enabled in accordance with organizational policy, procedures, prerequisites, and criteria. - system accounts are modified in accordance with organizational policy, procedures, prerequisites, and criteria. - system accounts are disabled in accordance with organizational policy, procedures, prerequisites, and criteria. - system accounts are removed in accordance with organizational policy, procedures, prerequisites, and criteria. - system a

Under the FedRAMP High baseline, AC-6.8 (AC-6.8 Privilege Levels for Code Execution): FedRAMP High Baseline · AC-6.8 · Privilege Levels for Code Execution Control Statement: Prevent the following software from executing at higher privilege levels than users executing the software: [organization-defined parameter]. Supplemental Guidance: Prevent the following software from executing at higher privilege levels than users executing the software: [organization-defined parameter]. In certain situations, software applications or programs need to execute with elevated privileges to pe

NIST SP 800-53 Rev 5 control AC-3.11 (Restrict Access to Specific Information Types) summarizes the requirements for this control: AC-3.11 · Restrict Access to Specific Information Types Control Statement: Restrict access to data repositories containing [organization-defined parameter]. Supplemental Guidance: Restrict access to data repositories containing [organization-defined parameter]. Restricting access to specific information is intended to provide flexibility regarding access control of specific information types within a system. For example, role-based access could be employed to allow access to only a specific ty

NIST SP 800-53 Rev 5 control AC-16.6 (Maintenance of Attribute Association) is defined as follows: AC-16.6 · Maintenance of Attribute Association Control Statement: Require personnel to associate and maintain the association of [organization-defined parameter] with [organization-defined parameter] in accordance with [organization-defined parameter]. Supplemental Guidance: Require personnel to associate and maintain the association of [organization-defined parameter] with [organization-defined parameter] in accordance with [organization-defined parameter]. Maintaining attribute association requires individual users (as opposed to the system) to maintain associations of defined security and

AC-6.7 · Review of User Privileges Control Statement: (a) Review [organization-defined parameter] the privileges assigned to [organization-defined parameter] to validate the need for such privileges; and (b) Reassign or remove privileges, if necessary, to correctly reflect organizational mission and business needs. Supplemental Guidance: (a) Review [organization-defined parameter] the privileges assigned to [organization-defined parameter] to validate the need for such privileges; and (b) Reassign or remove privileges, if necessary, to correctly reflect organizational mission and business needs. The need for certain assigned user privileges may change over time to reflect changes in organizational mission and business functions, environments of operation, technologies, or threats. A periodic review of assigned user privileges is necessary to determine if the rationale for assigning such privileges remains valid. If the need cannot be revalidated, organizations take appropriate corrective actions.

NIST SP 800-171 Rev 3 control 03.01.11 (03.01.11 Session Termination) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control AC-7.2 (Purge or Wipe Mobile Device) summarizes the requirements for this control: AC-7.2 · Purge or Wipe Mobile Device Control Statement: Purge or wipe information from [organization-defined parameter] based on [organization-defined parameter] after [organization-defined parameter] consecutive, unsuccessful device logon attempts. Supplemental Guidance: Purge or

wipe information from [organization-defined parameter] based on [organization-defined parameter] after [organization-defined parameter] consecutive, unsuccessful device logon attempts. A mobile device is a computing

NIST SP 800-171 Rev 3 control 03.01.03 (03.01.03 Information Flow Enforcement) falls under the Access Control family. 03.01.03 · Information Flow Enforcement Supplemental Guidance: Information flow control regulates where CUI can transit within a system and between systems (in contrast to who is allowed to access the information) and without regard to subsequent accesses to that information. Flow control restrictions include keeping CUI from being transmitted in the clear to the internet, blocking external communications traffic that claims to be sourced from within the organization, restricting requests to the Supplemental Guidance: Information flow control regulates where CUI can transit within a system and between systems (in contrast to who is allowed to access the information) and without regard to subsequent accesses to that information. Flow control restrictions include keeping CUI from being transmitted in the clear to the internet, blocking external communications traffic that claims to be sourced from within the organization, restricting requests to the internet that are not from the internal

AC-3.14 · Individual Access Control Statement: Provide [organization-defined parameter] to enable individuals to have access to the following elements of their personally identifiable information: [organization-defined parameter]. Supplemental Guidance: Provide [organization-defined parameter] to enable individuals to have access to the following elements of their personally identifiable information: [organization-defined parameter]. Individual access affords individuals the ability to review personally identifiable information about them held within organizational records, regardless of format. Access helps individuals to develop an understanding about how their personally identifiable information is being processed. It can also help individuals ensure that their data is accurate. Access mechanisms can include request forms and application interfaces. For federal agencies, [PRIVACT](#18e71fec-c6fd-475a-925a-5d8495cf8455) processes can be located in systems of record notices and on agency websites. Access to certain types of records may not be appropriate (e.g., for federal agencies, law enforcement records within a system of records may be exempt from disclosure under the [PRIVACT](#18e71fec-c6fd-475a-925a-5d8495cf8455)) or may require certain levels of authentication assurance. Organizational personnel consult with the senior agency official for privacy and legal counsel to determine appropriate mechanisms and access rights or limitations.

NIST SP 800-171 Rev 3 control 03.01.16 (03.01.16 Wireless Access) requires organizations to implement the following: Control Statement: SR-03.01.16.a Establish usage restrictions, configuration requirements, and connection requirements for each type of wireless access to the system. SR-03.01.16.b Authorize each type of wireless access to the system prior to establishing such connections. SR-03.01.16.c Disable, when not intended for use, wireless networking capabilities prior to issuance and deployment. SR-03.01.16.d Protect wireless access to the system using authentication and encryption. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.16.

NIST SP 800-53 Rev 5 control AC-4.22 (Access Only): AC-4.22 · Access Only Control Statement: Provide access from a single device to computing platforms, applications, or data residing in multiple different security domains, while preventing information flow between the different security domains. Supplemental Guidance: Provide access from a single device to computing platforms, applications, or data residing in multiple different security domains

AC-4.14 · Security or Privacy Policy Filter Constraints Control Statement: When transferring information between different security domains, implement [organization-defined parameter] requiring fully enumerated formats that restrict data structure and content. Supplemental Guidance: When transferring information between different security domains, implement [organization-defined parameter] requiring fully enumerated formats that restrict data structure and content. Data structure and content restrictions reduce the range of potential malicious or unsanctioned content in cross-domain transactions. Security or privacy policy filters that restrict data structures include restricting file sizes and field lengths. Data content policy filters include encoding formats for character sets, restricting character data fields to only contain alpha-numeric characters, prohibiting special characters, and validating schema structures.

NIST SP 800-53 Rev 5 control AC-22 (Publicly Accessible Content) summarizes the requirements for this control: AC-22 · Publicly Accessible Content Control Statement: a. Designate individuals authorized to make information publicly accessible; b. Train authorized individuals to ensure that publicly accessible information does not contain nonpublic information; c. Review the proposed content of information prior to posting onto the publicly accessible system to ensure that nonpublic information is not included; and d. Review the content on the publicly accessible system for nonpublic information [organiza

Under the FedRAMP High baseline, AC-18 (AC-18 Wireless Access): FedRAMP High Baseline · AC-18 · Wireless Access Control Statement: a. Establish configuration requirements, connection requirements, and implementation guidance for each type of wireless access; and b. Authorize each type of wireless access to the system prior to allowing such connections. Supplemental Guidance: a. Establish configuration requirements, connection requirements, and implementation guidance for each type of wireless access; and b. Authorize each type of wireless access to the sys

and (b) Provide the means for authorized individuals to determine the identity of the producer of the information. Discussion: Binding identities to the information supports audit requirements that provide organizational personnel with the means to identify who produced specific information in the event of an information transfer. Organizations determine and approve the strength of attribute binding between the information producer and the information based on the security category of the information and other relevant risk factors. Related Controls: AC-4, AC-16.

NIST SP 800-53 Rev 5 control AC-16.9 (Attribute Reassignment · Regrading Mechanisms) summarizes the requirements for this control: AC-16.9 · Attribute Reassignment · Regrading Mechanisms Control Statement: Change security and privacy attributes associated with information only via regrading mechanisms validated using [organization-defined parameter]. Supplemental Guidance: Change security and privacy attributes associated with information only via regrading mechanisms validated using [organization-defined parameter]. A regrading mechanism is a trusted process authorized to re-classify and re-label data in accordance with

NIST SP 800-53 Rev 5 control AC-2.9 (Restrictions on Use of Shared and Group Accounts) is assessed by examining, interviewing, and testing: AC-2.9 · Restrictions on Use of Shared and Group Accounts Control Statement: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Supplemental Guidance: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Before permitting the use of shared or group accounts, organizations consider the increased risk due to the lack of accountability with such accounts.

AC-12.1 · User-initiated Logouts Control Statement: Provide a logout capability for user-initiated communications sessions whenever authentication is used to gain access to [organization-defined parameter]. Supplemental Guidance: Provide a logout capability for user-initiated communications sessions whenever authentication is used to gain access to [organization-defined parameter]. Information resources to which users gain access via authentication include local workstations, databases, and password-protected websites or web-based services.

NIST SP 800-53 Rev 5 control AC-14 (Permitted Actions Without Identification or Authentication) is assessed by examining, interviewing, and testing: AC-14 · Permitted Actions Without Identification or Authentication Control Statement: a. Identify [organization-defined parameter] that can be performed on the system without identification or authentication consistent with organizational mission and business functions; and b. Document and provide supporting rationale in the security plan for the system, user actions not requiring identification or authentication. Supplemental Guidance: a. Identify [organization-defined parameter] that can be

NIST SP 800-53 Rev 5 control AC-16.2 (Attribute Value Changes by Authorized Individuals) is defined as follows: AC-16.2 · Attribute Value Changes by Authorized Individuals Control Statement: Provide authorized individuals (or processes acting on behalf of individuals) the capability to define or change the value of associated security and privacy attributes. Supplemental Guidance: Provide authorized individuals (or processes acting on behalf of individuals) the capability to define or change the value of associated security and privacy attributes. The content or assigned values of attributes can directly affect the ability of individuals to access organizational information. Therefore, it is important

NIST SP 800-53 Rev 5 control AC-20.5 (Portable Storage Devices · Prohibited Use) is defined as follows: AC-20.5 · Portable Storage Devices · Prohibited Use Control Statement: Prohibit the use of organization-controlled portable storage devices by authorized individuals on external systems. Supplemental Guidance: Prohibit the use of organization-controlled portable storage devices by authorized individuals on external systems. Limits on the use of organization-controlled portable storage devices in external systems include a complete prohibition of the use of such devices. Prohibiting such use is enforced using technical methods and/or nontechnical (i.e., process-based) methods.

NIST SP 800-53 Rev 5 control AC-12 (Session Termination) summarizes the requirements for this control: AC-12 · Session Termination Control Statement: Automatically terminate a user session after [organization-defined parameter]. Supplemental Guidance: Automatically terminate a user session after [organization-defined parameter]. Session termination addresses the termination of user-initiated logical sessions (in contrast to [SC-10](#sc-10) , which addresses the termination of network connections associated with communications sessions (i.e., network disconnect)). A logical session (for local, n

NIST SP 800-53 Rev 5 control AC-3.13 (Attribute-based Access Control) is assessed by examining, interviewing, and testing: AC-3.13 · Attribute-based Access Control Control Statement: Enforce attribute-based access control policy over defined subjects and objects and control access based upon [organization-defined parameter]. Supplemental Guidance: Enforce attribute-based access control policy over defined subjects and objects and control access based upon [organization-defined parameter]. Attribute-based access control is an access control policy that restricts system access to authorized users based on specified

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: AC-02, AC-02(03), AC-02(05), AC-02(13) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.01.f.02 [Assignment: organization-defined time period] at most 90 days 03.01.01.g.01 [Assignment: organization-defined time period] 24 hours 03.01.01.g.02 [Assignment: organization-defined time period] 24 hours 03.01.01.g.03 [Assignment: organization-defined time period] 24 hours 03.01.01.h.01 [Assignment: organization-defined time period] at most 24 hours 03.01.01.h.02 [Assignment: organization-defined circumstances] the work period ends, for privileged users at a minimum

Under the FedRAMP Moderate baseline, AC-2.13 (AC-2.13 Disable Accounts for High-risk Individuals): FedRAMP Moderate Baseline · AC-2.13 · Disable Accounts for High-risk Individuals Control Statement: Disable accounts of individuals within [organization-defined parameter] of discovery of [organization-defined parameter]. Supplemental Guidance: Disable accounts of individuals within [organization-defined parameter] of discovery of [organization-defined parameter]. Users who pose a significant security and/or privacy risk include individuals for whom reliable evidence indicates either the inten

Under the FedRAMP Moderate baseline, AC-2.4 (AC-2.4 Automated Audit Actions): FedRAMP Moderate Baseline · AC-2.4 · Automated Audit Actions Control Statement: Automatically audit account creation, modification, enabling, disabling, and removal actions. Supplemental Guidance: Automatically audit account creation, modification, enabling, disabling, and removal actions. Account management audit records are defined in accordance with [AU-2](#au-2) and reviewed, analyzed, and reported in accordance with [AU-6](#au-6). Assessment Objectives: Automatically audit account creati

NIST SP 800-53 Rev 5 control AC-2.9 (Restrictions on Use of Shared and Group Accounts) summarizes the requirements for this control: AC-2.9 · Restrictions on Use of Shared and Group Accounts Control Statement: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Supplemental Guidance: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Before permitting the use of shared or group accounts, organizations consider the increased risk due to the lack of accountability with such accounts.

From the NIST SP 800-172 Rev 3 Final Public Draft: PRA 615 A DVERSARY EFFECTS 616 P reclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-04(01) 03.0 1.11E R ole-Based Access

Control a. Enforce a role-based access control policy over defined subjects and objects. b. Control access based upon [Assignment: organization-defined roles and users authorized to assume such roles]. DISCUSSION Role-based access control (RBAC) is an access control policy that enforces access to objects and system functions based on the defined role (i.e., job function) of the subject. Organizations can create specific roles based on job functions and the authorizations (i.e., privileges) to perform needed operations on the systems associated with the organization-defined roles. When users are assigned to specific roles, they inherit the auth

NIST SP 800-53 Rev 5 control AC-4.25 (Data Sanitization) is assessed by examining, interviewing, and testing: AC-4.25 · Data Sanitization Control Statement: When transferring information between different security domains, sanitize data to minimize [organization-defined parameter] in accordance with [organization-defined parameter]. Supplemental Guidance: When transferring information between different security domains, sanitize data to minimize [organization-defined parameter] in accordance with [organization-defined parameter]. Data sanitization is the process of irreversibly removing or destroying

From the NIST SP 800-172 Rev 3 Final Public Draft: Enforcing the separation of information flows associated with defined types of data can enhance protection by ensuring that CUI is not commingled while in transit and by enabling flow control by transmission paths that are not otherwise achievable. This requirement enhances SP 800-171 requirement 03.01.03. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-04(21) 03.01.13E Metadata Enforce information flow control based on [Assignment: organization-defined metadata]. DISCUSSION Metadata is information that describes the characteristics of data. Metadata can include structural metadata that describes data structures or descriptive metadata that describes data content. The enforcement of allowed information flows base

NIST SP 800-171 Rev 3 control 03.01.01 (03.01.01 Account Management) falls under the Access Control family. Control Statement: SR-03.01.01.a Define the types of system accounts allowed and prohibited. SR-03.01.01.b Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria. SR-03.01.01.c Specify: SR-03.01.01.c.01 Authorized users of the system, SR-03.01.01.c.02 Group and role membership, and SR-03.01.01.c.03 Access authorizations (i.e., privileges) for each account. SR-03.01.01.d Authorize access to the system based on: SR-03.01.01.d.01 A valid access authorization and SR-03.01.01.d.02 Intended system usage. SR-03.01.01.e Monitor the use of system accounts. SR-03.01.01.f Disable system accounts when: SR-03.01.01.f.01 The accounts have expired, SR-03.01.01.f.02 The accounts have been inactive for [organization-defined parameter], SR-03.01.01.f.03 The accounts are no longer associated with a user or individual, SR-03.01.01.f.04 The accounts are in violation of organizational policy, or SR-03.01.01.f.05 Significant risks associated with individuals are discovered. SR-03.01.01.g Notify account managers and designated personnel or roles within: SR-03.01.01.g.01 [organization-defined parameter] when accounts are no longer required. SR-03.01.01.g.02 [organization-defined parameter] when users are terminated or transferred. SR-03.01.01.g.03 [organization-defined parameter] when system usage or the need-to-know changes for an individual. SR-03.01.01.h Require that users log out of the system after [organization-defined parameter] of expected inactivity or when [organization-defined parameter]. Supplemental Guidance: This requirement focuses on account management for systems and applications. The definition and enforcement of access authorizations other than those determined by account type (e.g., privileged access, non-privileged access) are addressed in [(#/cprt/framework/version/SP_800_171_3_0_0/home?element=03.01.02)03.01.02. System account types include individual, group, temporary, system, guest, anonymous, emergency, developer, and service. Users who require administrative priv

Organizations can create rules based on specified attributes and the authorizations 579 (i.e., privileges) to perform needed operations on the systems associated with organization-defined attributes and rules. When users are assigned to attributes defined in attribute-based access control policies or rules, they can be provisioned to a system with the appropriate privileges or dynamically granted access to a protected resource. Attribute-based access control can be implemented as either a mandatory or discretionary form of access control. This requirement enhances SP 800-171 requirement 03.01.02. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-03(13) 03.01.10E Object Security Attributes Use [Assignment: organization-defined security attributes] associated with [Assignment:

organization-defined information, source, and destination objects] to enforce [Assignment: organization-defined information flow control policies] as a basis for flow control decisions.

DISCUSSION Organizations implement information flow control policies and enforcement mechanisms to control the flow of CUI between designated sources and destinations within systems and between connected systems. Flow control is based on the characteristics of the information and/or the information path. Enforcement occurs, for example, in boundary protection devices that employ rule sets or establish configuration settings that restrict system services, provide a packet-filtering capability based on header information, or provide a message-filtering capability based on message content. Information flow enforcement mechanisms compare the security attributes associated with information (i.e., data content and structure) and source and destination objects and respond appropriately when the enforcement mechanisms encounter information flows that are not explicitly allowed by information flow policies. Security attributes can also include source and destination addresses employed in traffic filter firewalls. Flow enforcement using explicit security attributes can be used, for example, to control the release of certain types of information. This requirement enhances SP 800-171 requirement 03.01.03.

PROTECTION STRATEGY

NIST SP 800-53 Rev 5 control AC-4.10 (Enable and Disable Security or Privacy Policy Filters) is assessed by examining, interviewing, and testing: AC-4.10 · Enable and Disable Security or Privacy Policy Filters Control Statement: Provide the capability for privileged administrators to enable and disable [organization-defined parameter] under the following conditions: [organization-defined parameter]. Supplemental Guidance: Provide the capability for privileged administrators to enable and disable [organization-defined parameter] under the following conditions: [organization-defined parameter]. For example, as allowed by the system author

AC-17.4 · Privileged Commands and Access Control Statement: (a) Authorize the execution of privileged commands and access to security-relevant information via remote access only in a format that provides assessable evidence and for the following needs: [organization-defined parameter] ; and (b) Document the rationale for remote access in the security plan for the system. Supplemental Guidance: (a) Authorize the execution of privileged commands and access to security-relevant information via remote access only in a format that provides assessable evidence and for the following needs: [organization-defined parameter] ; and (b) Document the rationale for remote access in the security plan for the system. Remote access to systems represents a significant potential vulnerability that can be exploited by adversaries. As such, restricting the execution of privileged commands and access to security-relevant information via remote access reduces the exposure of the organization and the susceptibility to threats by adversaries to the remote access capability.

Under the FedRAMP High baseline, AC-2.12 (AC-2.12 Account Monitoring for Atypical Usage): FedRAMP High Baseline · AC-2.12 · Account Monitoring for Atypical Usage Control Statement: (a) Monitor system accounts for [organization-defined parameter] ; and (b) Report atypical usage of system accounts to [organization-defined parameter]. Supplemental Guidance: (a) Monitor system accounts for [organization-defined parameter] ; and (b) Report atypical usage of system accounts to [organization-defined parameter]. Atypical usage includes accessing systems at certain times of the day or from

NIST SP 800-171 Rev 3 control 03.01.22 (03.01.22 Publicly Accessible Content) is assessed by examining the following: Assessment Objectives: - authorized individuals are trained to ensure that publicly accessible information does not contain CUI. - the content on publicly accessible systems is reviewed for CUI. - CUI is removed from publicly accessible systems, if discovered.

NIST SP 800-171 Rev 3 control 03.01.22 (03.01.22 Publicly Accessible Content) falls under the Access Control family. Control Statement: SR-03.01.22.a Train authorized individuals to ensure that publicly accessible information does not contain CUI. SR-03.01.22.b Review the content on publicly accessible systems for CUI and remove such information, if discovered. Supplemental Guidance: In accordance with applicable laws, Executive Orders, directives, policies, regulations, standards, and guidelines, the public is not authorized to have access to nonpublic information, including CUI.

NIST SP 800-53 Rev 5 control AC-6.9 (Log Use of Privileged Functions) is defined as follows: AC-6.9 · Log Use of Privileged Functions Control Statement: Log the execution of privileged functions. Supplemental Guidance: Log the execution of privileged functions. The misuse of privileged functions, either intentionally or unintentionally by authorized users or by unauthorized external

entities that have compromised system accounts, is a serious and ongoing concern and can have significant adverse impacts on organizations. Logging and analyzing the use of privileged functions is one way to detect such misuse and, in doing so, help mitigate the risk from insider threats and the advanced

Access Control 3.1.10 Device Lock a. Prevent access to the system by [Selection (one or more): initiating a device lock after [Assignment: organization-defined time period] (03.01.10.a) of inactivity; requiring the user to initiate a device lock before leaving the system unattended]. b. Retain the device lock until the user reestablishes access using established identification and authentication procedures. c. Conceal, via the device lock, information previously visible on the display with a publicly viewable image. Related Controls: AC-11, AC-11(01) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.10.a [Assignment: organization-defined time period] initiating a device lock after ·at most 15 minutes· of inactivity and requiring the user to initiate a device lock before leaving the system unattended Access Control 3.1.11 Session Termination Terminate a user session automatically after [Assignment: organization-defined conditions or trigger events requiring session disconnect] (03.01.11). Related Controls: AC-12 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.11 [Assignment: organization-defined conditions or trigger events requiring session disconnect] a specified duration (maximum of 24 hours) of inactivity, misbehavior (end the session due to an attempted policy violation), and maintenance (terminate sessions to prevent issues with an upgrade or service outage)

NIST SP 800-171 Rev 3 control 03.01.18 (03.01.18 Access Control for Mobile Devices) requires organizations to implement the following: Control Statement: SR-03.01.18.a Establish usage restrictions, configuration requirements, and connection requirements for mobile devices. SR-03.01.18.b Authorize the connection of mobile devices to the system. SR-03.01.18.c Implement full-device or container-based encryption to protect the confidentiality of CUI on mobile devices. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.18.

NIST SP 800-53 Rev 5 control AC-16.3 (Maintenance of Attribute Associations by System) is assessed by examining, interviewing, and testing: AC-16.3 · Maintenance of Attribute Associations by System Control Statement: Maintain the association and integrity of [organization-defined parameter] to [organization-defined parameter]. Supplemental Guidance: Maintain the association and integrity of [organization-defined parameter] to [organization-defined parameter]. Maintaining the association and integrity of security and privacy attributes to subjects and objects with sufficient assurance helps to ensure that the attribute associations

NIST SP 800-53 Rev 5 control AC-16.1 (Dynamic Attribute Association) is defined as follows: AC-16.1 · Dynamic Attribute Association Control Statement: Dynamically associate security and privacy attributes with [organization-defined parameter] in accordance with the following security and privacy policies as information is created and combined: [organization-defined parameter]. Supplemental Guidance: Dynamically associate security and privacy attributes with [organization-defined parameter] in accordance with the following security and privacy policies as information is created and combined: [organization-defined parameter]. Dynamic association of attributes is appropriate whenever

03.01.22 · Publicly Accessible Content Control Statement: SR-03.01.22.a Train authorized individuals to ensure that publicly accessible information does not contain CUI. SR-03.01.22.b Review the content on publicly accessible systems for CUI and remove such information, if discovered. Supplemental Guidance: In accordance with applicable laws, Executive Orders, directives, policies, regulations, standards, and guidelines, the public is not authorized to have access to nonpublic information, including CUI. Assessment Objectives: - authorized individuals are trained to ensure that publicly accessible information does not contain CUI. - the content on publicly accessible systems is reviewed for CUI. - CUI is removed from publicly accessible systems, if discovered.

NIST SP 800-53 Rev 5 control AC-9.3 (Notification of Account Changes) summarizes the requirements for this control: AC-9.3 · Notification of Account Changes Control Statement: Notify the user, upon successful logon, of changes to [organization-defined parameter] during [organization-defined

parameter]. Supplemental Guidance: Notify the user, upon successful logon, of changes to [organization-defined parameter] during [organization-defined parameter]. Information about changes to security-related account characteristics within a specified time period allows users to recognize if changes were made without the

NIST SP 800-53 Rev 5 control AC-16.6 (Maintenance of Attribute Association) is assessed by examining, interviewing, and testing: AC-16.6 · Maintenance of Attribute Association Control Statement: Require personnel to associate and maintain the association of [organization-defined parameter] with [organization-defined parameter] in accordance with [organization-defined parameter]. Supplemental Guidance: Require personnel to associate and maintain the association of [organization-defined parameter] with [organization-defined parameter] in accordance with [organization-defined parameter]. Maintaining attribute association r

AC-4.27 · Redundant/Independent Filtering Mechanisms Control Statement: When transferring information between different security domains, implement content filtering solutions that provide redundant and independent filtering mechanisms for each data type. Supplemental Guidance: When transferring information between different security domains, implement content filtering solutions that provide redundant and independent filtering mechanisms for each data type. Content filtering is the process of inspecting information as it traverses a cross-domain solution and determines if the information meets a predefined policy. Redundant and independent content filtering eliminates a single point of failure filtering system. Independence is defined as the implementation of a content filter that uses a different code base and supporting libraries (e.g., two JPEG filters using different vendors' JPEG libraries) and multiple, independent system processes.

AC-9.3 · Notification of Account Changes Control Statement: Notify the user, upon successful logon, of changes to [organization-defined parameter] during [organization-defined parameter]. Supplemental Guidance: Notify the user, upon successful logon, of changes to [organization-defined parameter] during [organization-defined parameter]. Information about changes to security-related account characteristics within a specified time period allows users to recognize if changes were made without their knowledge.

NIST SP 800-53 Rev 5 control AC-6.10 (Prohibit Non-privileged Users from Executing Privileged Functions) is assessed by examining, interviewing, and testing: AC-6.10 · Prohibit Non-privileged Users from Executing Privileged Functions Control Statement: Prevent non-privileged users from executing privileged functions. Supplemental Guidance: Prevent non-privileged users from executing privileged functions. Privileged functions include disabling, circumventing, or altering implemented security or privacy controls, establishing system accounts, performing system integrity checks, and administering cryptographic key management activities. Non-privileged

Under the FedRAMP Low baseline, AC-8 (AC-8 System Use Notification): FedRAMP Low Baseline · AC-8 · System Use Notification Control Statement: a. Display [organization-defined parameter] to users before granting access to the system that provides privacy and security notices consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines and state that: 1. Users are accessing a U.S. Government system; 2. System usage may be monitored, recorded, and subject to audit; 3. Unauthorized use of the system is prohibi

Under the FedRAMP High baseline, AC-1 (AC-1 Policy and Procedures): FedRAMP High Baseline · AC-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] access control policy that: 2. Procedures to facilitate the implementation of the access control policy and the associated access controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the access control policy and procedures; and c. Review and

NIST SP 800-53 Rev 5 control AC-6.2 (Non-privileged Access for Nonsecurity Functions): AC-6.2 · Non-privileged Access for Nonsecurity Functions Control Statement: Require that users of system accounts (or roles) with access to [organization-defined parameter] use non-privileged accounts or roles, when accessing nonsecurity functions. Supplemental Guidance: Require that users of system accounts (or roles) with access to [organization-defined parameter] use non-privileged accounts o

NIST SP 800-53 Rev 5 control AC-6.6 (Privileged Access by Non-organizational Users) is defined as

follows: AC-6.6 · Privileged Access by Non-organizational Users Control Statement: Prohibit privileged access to the system by non-organizational users. Supplemental Guidance: Prohibit privileged access to the system by non-organizational users. An organizational user is an employee or an individual considered by the organization to have the equivalent status of an employee. Organizational users include contractors, guest researchers, or individuals detailed from other organizations. A non-organizational user is a user who is not an organizational user. Policies and procedures for granting equivalent

NIST SP 800-53 Rev 5 control AC-6.9 (Log Use of Privileged Functions) summarizes the requirements for this control: AC-6.9 · Log Use of Privileged Functions Control Statement: Log the execution of privileged functions. Supplemental Guidance: Log the execution of privileged functions. The misuse of privileged functions, either intentionally or unintentionally by authorized users or by unauthorized external entities that have compromised system accounts, is a serious and ongoing concern and can have significant adverse impacts on organizations. Logging and analyzing the use of privileged functions is one way

NIST SP 800-53 Rev 5 control AC-16.1 (Dynamic Attribute Association) is assessed by examining, interviewing, and testing: AC-16.1 · Dynamic Attribute Association Control Statement: Dynamically associate security and privacy attributes with [organization-defined parameter] in accordance with the following security and privacy policies as information is created and combined: [organization-defined parameter]. Supplemental Guidance: Dynamically associate security and privacy attributes with [organization-defined parameter] in accordance with the following security and privacy policies as information is created and co

Control AC-06(05): findings) that is necessary to determine whether the security requirements in SP 800-171 have been satisfied. 9 The report conveys the results of the assessment to designated organizational officials. The report can also provide recommendations for correcting any deficiencies discovered during the assessment. Depending on the organization's objective for the assessment, the assessment results can trigger a variety of risk response actions, including risk acceptance, risk mitigation, risk rejection, risk transfer, or risk sharing. The assessment results can also influence changes to the system security plan and plan of action and milestones. Table 5 provides a summary of the purpose and expected outcomes of the assessment analysis, documentation, and reporting phase . Table 5. Summary of Assessment Analysis, Documentation, and Reporting Phase | PURPOSE | Analyze the risks that result from the weaknesses and deficiencies identified during the assessment, and determine an approach to respond to those risks in accordance with organizational priorities. | |-----|-----|

-----| | OUTCOMES | · Assessment findings are reviewed and analyzed. · Subsequent risk responses are initiated to manage risks. · The system security plan and plan of action and milestones are updated to reflect the results of the assessment and any subsequent risk response actions. | 9 SP 800-53A, Appendix E provides additional guidance on security assessment reports. ## Appendix D. Organization-Defined Parameters This appendix lists the organization-defined parameters (ODPs) that are included in the assessment procedures in Sec. 3.

AC-4.3 · Dynamic Information Flow Control Control Statement: Enforce [organization-defined parameter]. Supplemental Guidance: Enforce [organization-defined parameter]. Organizational policies regarding dynamic information flow control include allowing or disallowing information flows based on changing conditions or mission or operational considerations. Changing conditions include changes in risk tolerance due to changes in the immediacy of mission or business needs, changes in the threat environment, and detection of potentially harmful or adverse events.

NIST SP 800-53 Rev 5 control AC-6.4 (Separate Processing Domains) is assessed by examining, interviewing, and testing: AC-6.4 · Separate Processing Domains Control Statement: Provide separate processing domains to enable finer-grained allocation of user privileges. Supplemental Guidance: Provide separate processing domains to enable finer-grained allocation of user privileges. Providing separate processing domains for finer-grained allocation of user privileges includes using virtualization techniques to permit additional user privileges within a virtual machine while restricting privileges to other virtual ma

NIST SP 800-53 Rev 5 control AC-12.1 (User-initiated Logouts) is assessed by examining, interviewing, and testing: AC-12.1 · User-initiated Logouts Control Statement: Provide a logout capability for user-initiated communications sessions whenever authentication is used to gain access to [organization-defined parameter]. Supplemental Guidance: Provide a logout capability for user-initiated communications sessions whenever authentication is used to gain access to [organization-defined parameter]. Information resources to which users gain access via authentication include local workstations, databases, and pa

Under the FedRAMP Low baseline, AC-20 (AC-20 Use of External Systems): FedRAMP Low Baseline · AC-20 · Use of External Systems Control Statement: a. [organization-defined parameter] , consistent with the trust relationships established with other organizations owning, operating, and/or maintaining external systems, allowing authorized individuals to: 1. Access the system from external systems; and 2. Process, store, or transmit organization-controlled information using external systems; or b. Prohibit the use of [organization-defined parameter]. Supplemental

Implementing 03.01.04 (03.01.04 Separation of Duties) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.01.04 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.01.04 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-171 Rev 3 control 03.01.02 (03.01.02 Access Enforcement) is assessed by examining the following: Assessment Objectives: - approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies. - approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.

Under the FedRAMP High baseline, AC-2.7 (AC-2.7 Privileged User Accounts): FedRAMP High Baseline · AC-2.7 · Privileged User Accounts Control Statement: (a) Establish and administer privileged user accounts in accordance with [organization-defined parameter]; (b) Monitor privileged role or attribute assignments; (c) Monitor changes to roles or attributes; and (d) Revoke access when privileged role or attribute assignments are no longer appropriate. Supplemental Guidance: (a) Establish and administer privileged user accounts in accordance with [organization-defined par

Access Control 3.1.5 System Access Authorization a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks. b. Authorize access to: 1. [Assignment: organization-defined security functions] (03.01.05.b.01), and 2. [Assignment: organization-defined security-relevant information] (03.01.05.b.02). c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency](03.01.05.c) to validate the need for such privileges. d. Reassign or remove privileges, as necessary. Related Controls: AC-06, AC-06(01), AC-06(07), AU-09(04) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.01.05.b.01 [Assignment: organization-defined security functions] at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information 03.01.05.b.02 [Assignment: organization-defined security-relevant information] at a minimum and if applicable: threat and vulnerability information, filtering rules for routers or firewalls, configuration parameters for security services, cryptographic key management information, security architecture, access control lists, and audit information 03.01.05.c [Assignment: organization-defined frequency] at least every 12 months

NIST SP 800-53 Rev 5 control AC-17.1 (Monitoring and Control) is assessed by examining, interviewing, and testing: AC-17.1 · Monitoring and Control Control Statement: Employ automated

mechanisms to monitor and control remote access methods. Supplemental Guidance: Employ automated mechanisms to monitor and control remote access methods. Monitoring and control of remote access methods allows organizations to detect attacks and help ensure compliance with remote access policies by auditing the connection activities of remote users on a variety of system components, including servers, notebook computers, works

AC-2.1 · Automated System Account Management Control Statement: Support the management of system accounts using [organization-defined parameter]. Supplemental Guidance: Support the management of system accounts using [organization-defined parameter]. Automated system account management includes using automated mechanisms to create, enable, modify, disable, and remove accounts; notify account managers when an account is created, enabled, modified, disabled, or removed, or when users are terminated or transferred; monitor system account usage; and report atypical system account usage. Automated mechanisms can include internal system functions and email, telephonic, and text messaging notifications.

NIST SP 800-53 Rev 5 control AC-7 (Unsuccessful Logon Attempts) summarizes the requirements for this control: AC-7 · Unsuccessful Logon Attempts Control Statement: a. Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during a [organization-defined parameter] ; and b. Automatically [organization-defined parameter] when the maximum number of unsuccessful attempts is exceeded. Supplemental Guidance: a. Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during a [organization-defined parameter] ; and b. Automatica

NIST SP 800-171 Rev 3 control 03.01.02 (03.01.02 Access Enforcement) is assessed by examining the following: Assessment Objectives: - approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies. - approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.

Under the FedRAMP Moderate baseline, AC-2.9 (AC-2.9 Restrictions on Use of Shared and Group Accounts): FedRAMP Moderate Baseline · AC-2.9 · Restrictions on Use of Shared and Group Accounts Control Statement: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Supplemental Guidance: Only permit the use of shared and group accounts that meet [organization-defined parameter]. Before permitting the use of shared or group accounts, organizations consider the increased risk due to the lack of accountability with such accounts. Assessment Objectives: Only perm

NIST SP 800-53 Rev 5 control AC-18.3 (Disable Wireless Networking) is assessed by examining, interviewing, and testing: AC-18.3 · Disable Wireless Networking Control Statement: Disable, when not intended for use, wireless networking capabilities embedded within system components prior to issuance and deployment. Supplemental Guidance: Disable, when not intended for use, wireless networking capabilities embedded within system components prior to issuance and deployment. Wireless networking capabilities that are embedded within system components represent a significant potential vulnerability that can be exploit

NIST SP 800-171 Rev 3 control 03.01.20 (03.01.20 Use of External Systems) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.01.01 (03.01.01 Account Management) is assessed by examining the following: Assessment Objectives: - system accounts are created in accordance with organizational policy, procedures, prerequisites, and criteria. - system accounts are enabled in accordance with organizational policy, procedures, prerequisites, and criteria. - system accounts are modified in accordance with organizational policy, procedures, prerequisites, and criteria. - system accounts are disabled in accordance with organizational policy, procedures, prerequisites, and criteria. - system accounts are removed in accordance with organizational policy, procedures, prerequisites, and criteria. - system a

NIST SP 800-53 Rev 5 control AC-6.8 (Privilege Levels for Code Execution) is assessed by examining,

interviewing, and testing: AC-6.8 · Privilege Levels for Code Execution Control Statement: Prevent the following software from executing at higher privilege levels than users executing the software: [organization-defined parameter]. Supplemental Guidance: Prevent the following software from executing at higher privilege levels than users executing the software: [organization-defined parameter]. In certain situations, software applications or programs need to execute with elevated privileges to perform required functions

AC-16.2 · Attribute Value Changes by Authorized Individuals Control Statement: Provide authorized individuals (or processes acting on behalf of individuals) the capability to define or change the value of associated security and privacy attributes. Supplemental Guidance: Provide authorized individuals (or processes acting on behalf of individuals) the capability to define or change the value of associated security and privacy attributes. The content or assigned values of attributes can directly affect the ability of individuals to access organizational information. Therefore, it is important for systems to be able to limit the ability to create or modify attributes to authorized individuals.

Under the FedRAMP Moderate baseline, AC-18.1 (AC-18.1 Authentication and Encryption): FedRAMP Moderate Baseline · AC-18.1 · Authentication and Encryption Control Statement: Protect wireless access to the system using authentication of [organization-defined parameter] and encryption. Supplemental Guidance: Protect wireless access to the system using authentication of [organization-defined parameter] and encryption. Wireless networking capabilities represent a significant potential vulnerability that can be exploited by adversaries. To protect systems with wireless access points,

NIST SP 800-171 Rev 3 control 03.01.08 (03.01.08 Unsuccessful Logon Attempts) falls under the Access Control family. Control Statement: SR-03.01.08.a Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during a [organization-defined parameter]. SR-03.01.08.b Automatically [organization-defined parameter] when the maximum number of unsuccessful attempts is exceeded. Supplemental Guidance: Due to the potential for denial of service, automatic system lockouts are in most cases, temporary and automatically release after a predetermined time period established by the organization (i.e., using a delay algorithm). Organizations may employ different delay algorithms for different system components based on the capabilities of the respective components. Responses to unsuccessful system logon attempts may be implemented at the system and application levels. Organiza

Control AC-3: eloper's perspective regarding the experience of the build team, inclusive of FIDO, the AppAuth library, PKCE, and Chrome Custom Tabs. AppAuth was integrated as described in Section C.1 of Appendix C. From an application developer perspective, the primary emphasis in the build was integrating AppAuth. The authentication technology was basically transparent to the developer. In fact, the native application developers for this project had no visibility to the FIDO U2F or UAF integration. This transparency was achieved through the AppAuth pattern of delegating the authentication process to the in-application browser tab capability of the OS. Other application developer effects are listed below: - · Several pieces of information must be supplied by an application in the OAuth authorization request, such as the scope and the client ID, which an OAuth AS might use to apply appropriate authentication policy. These details are obtained during the OAuth client registration process with the AS. - · The ability to support multiple IdPs without requiring any hard-coding of IdP URLs in the application itself was achieved by using Hypertext Markup Language (HTML) forms hosted by the IdP to collect information from end users (e.g., domain) during login, which was used to perform IdP discovery. ## 4.6 Identity Provider Perspective of the Build The IdP is responsible for account and attribute creation and maintenance, as well as credential provisioning, management, and deprovisioning. Some IdP concerns for this architecture are listed below: - · Enrollment/registration of authenticators: IdPs should consider the enrollment process and lifecycle management for MFA. For this NCCoE project, FIDO UAF enrollment was launched by the user via tapping a native enrollment application (Nok Nok Labs' Passport application). During user authentication, the same application (Passport) was invoked programmatically (via AppLink) to perform FIDO authentication.

NIST SP 800-53 Rev 5 control AC-3.7 (Role-based Access Control) summarizes the requirements for this control: AC-3.7 · Role-based Access Control Control Statement: Enforce a role-based access control policy over defined subjects and objects and control access based upon [organization-defined

parameter]. Supplemental Guidance: Enforce a role-based access control policy over defined subjects and objects and control access based upon [organization-defined parameter]. Role-based access control (RBAC) is an access control policy that enforces access to objects and system functions based on the defined role

NIST SP 800-53 Rev 5 control AC-4.8 (Security and Privacy Policy Filters) is assessed by examining, interviewing, and testing: AC-4.8 · Security and Privacy Policy Filters Control Statement: (a) Enforce information flow control using [organization-defined parameter] as a basis for flow control decisions for [organization-defined parameter] ; and (b) [organization-defined parameter] data after a filter processing failure in accordance with [organization-defined parameter]. Supplemental Guidance: (a) Enforce information flow control using [organization-defined parameter] as a basis for flow control decisions for [organi

Implement mechanisms] to ensure [Assignment: organization-defined access control decisions] are applied to each access request prior to access enforcement. Discussion: Access control decisions (also known as authorization decisions) occur when authorization information is applied to specific accesses. In contrast, access enforcement occurs when systems enforce access control decisions. While it is common to have access control decisions and access enforcement implemented by the same entity, it is not required, and it is not always an optimal implementation choice. For some architectures and distributed systems, different entities may make access control decisions and enforce access. Related Controls: AC-2, AC-3. Control Enhancements: (1) ACCESS CONTROL DECISIONS | TRANSMIT ACCESS AUTHORIZATION INFORMATION Transmit [Assignment: organization-defined access authorization information] using [Assignment: organization-defined controls] to [Assignment: organization-defined systems] that enforce access control decisions. Discussion: Authorization processes and access control decisions may occur in separate parts of systems or in separate systems. In such instances, authorization information is transmitted securely (e.g., using cryptographic mechanisms) so that timely access control decisions can be enforced at the appropriate locations. To support the access control decisions, it may be necessary to transmit as part of the access authorization information supporting security and privacy attributes. This is because in distributed systems, there are various access control decisions that need to be made, and different entities make these decisions in a serial fashion, each requiring those attributes to make the decisions.

Under the FedRAMP Moderate baseline, AC-17.2 (AC-17.2 Protection of Confidentiality and Integrity Using Encryption): FedRAMP Moderate Baseline · AC-17.2 · Protection of Confidentiality and Integrity Using Encryption Control Statement: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Supplemental Guidance: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Virtual private networks can be used to protect the confidentiality and integrity of remote access sessions. Transport Layer Security (TLS) is

Under the FedRAMP High baseline, AC-4.21 (AC-4.21 Physical or Logical Separation of Information Flows): FedRAMP High Baseline · AC-4.21 · Physical or Logical Separation of Information Flows Control Statement: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Supplemental Guidance: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Enforcing the separation of information flows associated with defined types of data can enhance

NIST SP 800-53 Rev 5 control AC-6 (Least Privilege) is defined as follows: AC-6 · Least Privilege Control Statement: Employ the principle of least privilege, allowing only authorized accesses for users (or processes acting on behalf of users) that are necessary to accomplish assigned organizational tasks. Supplemental Guidance: Employ the principle of least privilege, allowing only authorized accesses for users (or processes acting on behalf of users) that are necessary to accomplish assigned organizational tasks. Organizations employ least privilege for specific duties and systems. The principle of least privilege is also applied to system processes, ensuring that

NIST SP 800-171 Rev 3 control 03.01.05 (03.01.05 Least Privilege) falls under the Access Control family. Control Statement: SR-03.01.05.a Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.

SR-03.01.05.b Authorize access to [organization-defined parameter] and [organization-defined parameter]. SR-03.01.05.c Review the privileges assigned to roles or classes of users [organization-defined parameter] to validate the need for such privileges. SR-03.01.05.d Reassign or remove privileges, as necessary. Supplemental Guidance: Organizations employ the principle of least privilege for specific duties and authorized access for users and system processes. Least privilege is applied to the development, implementation, and operation of the system. Organizations consider creating additional processes, roles, and system accounts to achieve least privilege. Security functions include establishing system accounts and assigning privileges, installing software, configuring access authorizations, configurin

Under the FedRAMP Low baseline, AC-14 (AC-14 Permitted Actions Without Identification or Authentication): FedRAMP Low Baseline · AC-14 · Permitted Actions Without Identification or Authentication Control Statement: a. Identify [organization-defined parameter] that can be performed on the system without identification or authentication consistent with organizational mission and business functions; and b. Document and provide supporting rationale in the security plan for the system, user actions not requiring identification or authentication. Supplemental Guidance: a. Identify [organization-defined

NIST SP 800-53 Rev 5 control AC-20 (Use of External Systems) is assessed by examining, interviewing, and testing: AC-20 · Use of External Systems Control Statement: a. [organization-defined parameter] , consistent with the trust relationships established with other organizations owning, operating, and/or maintaining external systems, allowing authorized individuals to: 1. Access the system from external systems; and 2. Process, store, or transmit organization-controlled information using external systems; or b. Prohibit the use of [organization-defined parameter]. Supplemental Guidance: a. [organizati

NIST SP 800-53 Rev 5 control AC-10 (Concurrent Session Control) is assessed by examining, interviewing, and testing: AC-10 · Concurrent Session Control Control Statement: Limit the number of concurrent sessions for each [organization-defined parameter] to [organization-defined parameter]. Supplemental Guidance: Limit the number of concurrent sessions for each [organization-defined parameter] to [organization-defined parameter]. Organizations may define the maximum number of concurrent sessions for system accounts globally, by account type, by account, or any combination thereof. For example, organizations ma

NIST SP 800-53 Rev 5 control AC-6.7 (Review of User Privileges) is assessed by examining, interviewing, and testing: AC-6.7 · Review of User Privileges Control Statement: (a) Review [organization-defined parameter] the privileges assigned to [organization-defined parameter] to validate the need for such privileges; and (b) Reassign or remove privileges, if necessary, to correctly reflect organizational mission and business needs. Supplemental Guidance: (a) Review [organization-defined parameter] the privileges assigned to [organization-defined parameter] to validate the need for such privileges; and (b) Reas

Under the FedRAMP Moderate baseline, AC-2.12 (AC-2.12 Account Monitoring for Atypical Usage): FedRAMP Moderate Baseline · AC-2.12 · Account Monitoring for Atypical Usage Control Statement: (a) Monitor system accounts for [organization-defined parameter] ; and (b) Report atypical usage of system accounts to [organization-defined parameter]. Supplemental Guidance: (a) Monitor system accounts for [organization-defined parameter] ; and (b) Report atypical usage of system accounts to [organization-defined parameter]. Atypical usage includes accessing systems at certain times of the day or f

AC-17.2 · Protection of Confidentiality and Integrity Using Encryption Control Statement: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Supplemental Guidance: Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions. Virtual private networks can be used to protect the confidentiality and integrity of remote access sessions. Transport Layer Security (TLS) is an example of a cryptographic protocol that provides end-to-end communications security over networks and is used for Internet communications and online transactions.

implement appropriate safeguards to ensure delivery of critical services. | Syntactic | Intersects with | PR-P | Develop and implement appropriate data processing safeguards. | | PR.AC | Access to

physical and logical assets and associated facilities is limited to authorized users, processes, and devices, and is managed consistent with the assessed risk of unauthorized access to authorized activities and transactions. | Functional | Intersects with | PR.AC-P | Access to data and devices is limited to authorized individuals, processes, and devices, and is managed consistent with the assessed risk of unauthorized access. | | PR.AC-1 | Identities and credentials are issued, managed, verified, revoked, and audited for authorized devices, users, and processes | Semantic | Equal to | PR.AC-P1 | Identities and credentials are issued, managed, verified, revoked, and audited for authorized individuals, processes, and devices. | | PR.AC-2 | Physical access to assets is managed and protected | Functional | Superset of | PR.AC-P2 | Physical access to data and devices is managed. |

NIST SP 800-53 Rev 5 control AC-20.1 (Limits on Authorized Use) summarizes the requirements for this control: AC-20.1 · Limits on Authorized Use Control Statement: Permit authorized individuals to use an external system to access the system or to process, store, or transmit organization-controlled information only after: (a) Verification of the implementation of controls on the external system as specified in the organization's security and privacy policies and security and privacy plans; or (b) Retention of approved system connection or processing agreements with the organizational entity hosting the

Under the FedRAMP High baseline, AC-18.4 (AC-18.4 Restrict Configurations by Users): FedRAMP High Baseline · AC-18.4 · Restrict Configurations by Users Control Statement: Identify and explicitly authorize users allowed to independently configure wireless networking capabilities. Supplemental Guidance: Identify and explicitly authorize users allowed to independently configure wireless networking capabilities. Organizational authorizations to allow selected users to configure wireless networking capabilities are enforced, in part, by the access enforcement mechanisms employed wi

NIST SP 800-53 Rev 5 control AC-3.9 (Controlled Release) is defined as follows: AC-3.9 · Controlled Release Control Statement: Release information outside of the system only if: (a) The receiving [organization-defined parameter] provides [organization-defined parameter] ; and (b) [organization-defined parameter] are used to validate the appropriateness of the information designated for release. Supplemental Guidance: Release information outside of the system only if: (a) The receiving [organization-defined parameter] provides [organization-defined parameter] ; and (b) [organization-defined parameter] are used to validate the appropriateness of the information designated

NIST SP 800-53 Rev 5 control AC-3.10 (Audited Override of Access Control Mechanisms) summarizes the requirements for this control: AC-3.10 · Audited Override of Access Control Mechanisms Control Statement: Employ an audited override of automated access control mechanisms under [organization-defined parameter] by [organization-defined parameter]. Supplemental Guidance: Employ an audited override of automated access control mechanisms under [organization-defined parameter] by [organization-defined parameter]. In certain situations, such as when there is a threat to human life or an event that threatens the organization's ab

NIST SP 800-53 Rev 5 control AC-25 (Reference Monitor) summarizes the requirements for this control: AC-25 · Reference Monitor Control Statement: Implement a reference monitor for [organization-defined parameter] that is tamperproof, always invoked, and small enough to be subject to analysis and testing, the completeness of which can be assured. Supplemental Guidance: Implement a reference monitor for [organization-defined parameter] that is tamperproof, always invoked, and small enough to be subject to analysis and testing, the completeness of which can be assured. A reference monitor is a s

NIST SP 800-53 Rev 5 control AC-1 (Policy and Procedures) is assessed by examining, interviewing, and testing: AC-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] access control policy that: 2. Procedures to facilitate the implementation of the access control policy and the associated access controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the access control policy and procedures; and c. Review and update the current acces

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.01.17E Detection of Unsanctioned CUI 740 a.

Examine CUI for the presence of [Assignment: organization-defined unsanctioned information] when transferring information between different security domains. b. Prohibit the transfer of the CUI defined in 03.01.17E.a in accordance with the [Assignment: organization-defined security policy].

DISCUSSION Unsanctioned information includes malicious code, information that is inappropriate for release from the source network, or executable code that could disrupt or harm services or systems on the destination network. This requirement enhances SP 800-171 requirement 03.01.03.

PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert)

REFERENCES Source Control: AC-04(15) 3.2. Awareness and Training 03.0 2.01E A dva

NIST SP 800-171 Rev 3 control 03.01.10 (03.01.10 Device Lock) is assessed by examining the following: Assessment Objectives: - access to the system is prevented by [organization-defined parameter]. - information previously visible on the display is concealed via device lock with a publicly viewable image. - the device lock is retained until the user reestablishes access using established identification and authentication procedures.

signatures on Authentication Information | | DTR-07.03.01.02 | If RSA with PSS padding is used, the parameters field of the AlgorithmIdentifier type shall assert SHA-256 (OID = 2.16.840.1.101.3.4.2.1). For RSA with PKCS #1 v1.5 padding, the parameters field is populated with NULL. For ECDSA, the parameters field is absent. | · [PROF], Worksheet titled - Derived PIV Authentication Certificate Profile | | DTR-07.03.01.03 | The subjectPublicKeyInfo field shall assert an algorithm in the AlgorithmIdentifier in accordance with Table 3-4 of [SP800-78]. | · [SP800-78], Section 3.2.2 - Specification of Public Keys In X.509 Certificates | | DTR-07.03.01.04 | If the public key algorithm is elliptic curve, then the parameters field contains the namedCurve choice populated with the OID for Curve P-256 (1.2.840.10045.3.1.7). | · [PROF], Worksheet titled - Derived PIV Authentication Certificate Profile | | DTR-07.03.01.05 | The keyUsage extension shall assert only the digitalSignature bit. No other bits shall be asserted. | · [PROF], Worksheet titled - Derived PIV Authentication Certificate Profile | | DTR-07.03.01.06 | The policyIdentifier field in the certificatePolicies must assert id-fpki- | · [PROF], Worksheet titled - Derived PIV |

Under the FedRAMP High baseline, AC-17.1 (AC-17.1 Monitoring and Control): FedRAMP High Baseline · AC-17.1 · Monitoring and Control Control Statement: Employ automated mechanisms to monitor and control remote access methods. Supplemental Guidance: Employ automated mechanisms to monitor and control remote access methods. Monitoring and control of remote access methods allows organizations to detect attacks and help ensure compliance with remote access policies by auditing the connection activities of remote users on a variety of system components, including servers, n

NIST SP 800-53 Rev 5 control AC-4.15 (Detection of Unsanctioned Information) summarizes the requirements for this control: AC-4.15 · Detection of Unsanctioned Information Control Statement: When transferring information between different security domains, examine the information for the presence of [organization-defined parameter] and prohibit the transfer of such information in accordance with the [organization-defined parameter]. Supplemental Guidance: When transferring information between different security domains, examine the information for the presence of [organization-defined parameter] and prohibit the tr

NIST SP 800-53 Rev 5 control AC-21.2 (Information Search and Retrieval) summarizes the requirements for this control: AC-21.2 · Information Search and Retrieval Control Statement: Implement information search and retrieval services that enforce [organization-defined parameter]. Supplemental Guidance: Implement information search and retrieval services that enforce [organization-defined parameter]. Information search and retrieval services identify information system resources relevant to an information need.

Under the FedRAMP High baseline, AC-20 (AC-20 Use of External Systems): FedRAMP High Baseline · AC-20 · Use of External Systems Control Statement: a. [organization-defined parameter] , consistent with the trust relationships established with other organizations owning, operating, and/or maintaining external systems, allowing authorized individuals to: 1. Access the system from external systems; and 2. Process, store, or transmit organization-controlled information using external systems; or b. Prohibit the use of [organization-defined parameter]. Supplemental

NIST SP 800-53 Rev 5 control AC-7.4 (Use of Alternate Authentication Factor) is defined as follows: AC-7.4 · Use of Alternate Authentication Factor Control Statement: (a) Allow the use of

[organization-defined parameter] that are different from the primary authentication factors after the number of organization-defined consecutive invalid logon attempts have been exceeded; and (b) Enforce a limit of [organization-defined parameter] consecutive invalid logon attempts through use of the alternative factors by a user during a [organization-defined parameter]. Supplemental Guidance: (a) Allow the use of [organization-defined parameter] that are different from the primary authentication factors

From the NIST SP 800-172 Rev 3 Final Public Draft: To reduce the risk of collusion, organizations consider rotating dual authorization duties to other individuals. Organizations also consider the risk associated with implementing dual authorization when immediate responses are necessary to ensure public and environmental safety. This requirement enhances SP 800-171 requirement 03.01.02. P ROTECTION STRATEGY P RA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: AC-03(02) 03.0 1.02E Non- Organizationally Owned Systems - Restricted Use Restrict the use of non-organizationally owned systems or system components to process, store, or transmit CUI using [Assignment: organization-defined restrictions]. DISCUSSION Non-organizationally owned systems or system components include systems or system com

NIST SP 800-171 Rev 3 control 03.01.09 (03.01.09 System Use Notification) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control AC-5 (Separation of Duties): AC-5 · Separation of Duties Control Statement: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Supplemental Guidance: a. Identify and document [organization-defined parameter] ; and b. Define system access authorizations to support separation of duties. Separation of duties addresses the potential for abuse o

NIST SP 800-171 Rev 3 control 03.01.08 (03.01.08 Unsuccessful Logon Attempts) is assessed by examining the following: Assessment Objectives: - a limit of [organization-defined parameter] consecutive invalid logon attempts by a user during [organization-defined parameter] is enforced. - [organization-defined parameter] when the maximum number of unsuccessful attempts is exceeded.

Under the FedRAMP High baseline, AC-6.2 (AC-6.2 Non-privileged Access for Nonsecurity Functions): FedRAMP High Baseline · AC-6.2 · Non-privileged Access for Nonsecurity Functions Control Statement: Require that users of system accounts (or roles) with access to [organization-defined parameter] use non-privileged accounts or roles, when accessing nonsecurity functions. Supplemental Guidance: Require that users of system accounts (or roles) with access to [organization-defined parameter] use non-privileged accounts or roles, when accessing nonsecurity functions. Requiring the use of non-priv

NIST SP 800-171 Rev 3 control 03.01.11 (03.01.11 Session Termination) requires organizations to implement the following: 03.01.11 · Session Termination Supplemental Guidance: This requirement addresses the termination of user-initiated logical sessions in contrast to the termination of network connections that are associated with communications sessions (i.e., disconnecting from the network) in [/#/cppt/framework/version/SP_800_171_3_0_0/home?element=03.13.09]03.13.09. A logical session is initiated whenever a user (or processes acting on behalf of a user) accesses a system. Logical sessions can be terminated (a For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.11.

NIST SP 800-171 Rev 3 control 03.01.04 (03.01.04 Separation of Duties) requires organizations to implement the following: Control Statement: SR-03.01.04.a Identify the duties of individuals requiring separation. SR-03.01.04.b Define system access authorizations to support separation of duties. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.04.

NIST SP 800-171 Rev 3 control 03.01.10 (03.01.10 Device Lock) requires organizations to implement

the following: Control Statement: SR-03.01.10.a Prevent access to the system by [organization-defined parameter]. SR-03.01.10.b Retain the device lock until the user reestablishes access using established identification and authentication procedures. SR-03.01.10.c Conceal, via the device lock, information previously visible on the display with a publicly viewable image. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.10.

Under the FedRAMP High baseline, AC-20.2 (AC-20.2 Portable Storage Devices · Restricted Use): FedRAMP High Baseline · AC-20.2 · Portable Storage Devices · Restricted Use Control Statement: Restrict the use of organization-controlled portable storage devices by authorized individuals on external systems using [organization-defined parameter]. Supplemental Guidance: Restrict the use of organization-controlled portable storage devices by authorized individuals on external systems using [organization-defined parameter]. Limits on the use of organization-controlled portable storage devices

NIST SP 800-53 Rev 5 control AC-6.1 (Authorize Access to Security Functions) summarizes the requirements for this control: AC-6.1 · Authorize Access to Security Functions Control Statement: Authorize access for [organization-defined parameter] to: (a) [organization-defined parameter] ; and (b) [organization-defined parameter]. Supplemental Guidance: Authorize access for [organization-defined parameter] to: (a) [organization-defined parameter] ; and (b) [organization-defined parameter]. Security functions include establishing system accounts, configuring access authorizations (i.e., permissions, privileges), config

NIST SP 800-171 Rev 3 control 03.01.02 (03.01.02 Access Enforcement) falls under the Access Control family. 03.01.02 · Access Enforcement Supplemental Guidance: Access control policies control access between active entities or subjects (i.e., users or system processes acting on behalf of users) and passive entities or objects (i.e., devices, files, records, domains) in organizational systems. Types of system access include remote access and access to systems that communicate through external networks, such as the internet. Access enforcement mechanisms can also be employed at the application and serv Supplemental Guidance: Access control policies control access between active entities or subjects (i.e., users or system processes acting on behalf of users) and passive entities or objects (i.e., devices, files, records, domains) in organizational systems. Types of system access include remote access and access to systems that communicate through external networks, such as the internet. Access enforcement mechanisms can also be employed at the application and service levels to provide increased

NIST SP 800-53 Rev 5 control AC-2.4 (Automated Audit Actions) summarizes the requirements for this control: AC-2.4 · Automated Audit Actions Control Statement: Automatically audit account creation, modification, enabling, disabling, and removal actions. Supplemental Guidance: Automatically audit account creation, modification, enabling, disabling, and removal actions. Account management audit records are defined in accordance with [AU-02](#au-2) and reviewed, analyzed, and reported in accordance with [AU-06](#au-6).

Control AC-25: (i.e., latent flaws) that would prevent the enforcement of the security policy.

Related Controls: AC-3, AC-16, SA-8, SA-17, SC-3, SC-11, SC-39, SI-13. Control Enhancements: None.

References: None. CHAPTER THREE PAGE 58 This publication is available free of charge from: [https://doi.org/10.6028/NIST.SP.800-53r](https://doi.org/10.6028/NIST.SP.800-53r5)

5. | NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

3.2 AWARENESS AND TRAINING Quick link to Awareness and Training Summary Table

Under the FedRAMP High baseline, AC-11 (AC-11 Device Lock): FedRAMP High Baseline · AC-11 · Device Lock Control Statement: a. Prevent further access to the system by [organization-defined parameter] ; and b. Retain the device lock until the user reestablishes access using established identification and authentication procedures. Supplemental Guidance: a. Prevent further access to the system by [organization-defined parameter] ; and b. Retain the device lock until the user reestablishes access using established identification and authentication procedur

NIST SP 800-53 Rev 5 control AC-17.4 (Privileged Commands and Access) is assessed by examining, interviewing, and testing: AC-17.4 · Privileged Commands and Access Control Statement: (a)

Authorize the execution of privileged commands and access to security-relevant information via remote access only in a format that provides assessable evidence and for the following needs: [organization-defined parameter] ; and (b) Document the rationale for remote access in the security plan for the system. Supplemental Guidance: (a) Authorize the execution of privileged commands and access to security-relevant information via re

NIST SP 800-53 Rev 5 control AC-3.4 (Discretionary Access Control) is assessed by examining, interviewing, and testing: AC-3.4 · Discretionary Access Control Control Statement: Enforce [organization-defined parameter] over the set of covered subjects and objects specified in the policy, and where the policy specifies that a subject that has been granted access to information can do one or more of the following: (a) Pass the information to any other subjects or objects; (b) Grant its privileges to other subjects; (c) Change security attributes on subjects, objects, the system, or the system's components; (d) Choo

NIST SP 800-171 Rev 3 control 03.01.20 (03.01.20 Use of External Systems) is assessed by examining the following: Assessment Objectives: - the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: [organization-defined parameter]. - the use of external systems is prohibited unless the systems are specifically authorized. - authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have bee

NIST SP 800-171 Rev 3 control 03.01.12 (03.01.12 Remote Access) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Access Control (AC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control AC-2.4 (Automated Audit Actions) is assessed by examining, interviewing, and testing: AC-2.4 · Automated Audit Actions Control Statement: Automatically audit account creation, modification, enabling, disabling, and removal actions. Supplemental Guidance: Automatically audit account creation, modification, enabling, disabling, and removal actions. Account management audit records are defined in accordance with [AU-02](#au-2) and reviewed, analyzed, and reported in accordance with [AU-06](#au-6).

FedRAMP Moderate Baseline · AC-2.4 · Automated Audit Actions Control Statement: Automatically audit account creation, modification, enabling, disabling, and removal actions. Supplemental Guidance: Automatically audit account creation, modification, enabling, disabling, and removal actions. Account management audit records are defined in accordance with [AU-2](#au-2) and reviewed, analyzed, and reported in accordance with [AU-6](#au-6). Assessment Objectives: Automatically audit account creation, modification, enabling, disabling, and removal actions.

NIST SP 800-171 Rev 3 control 03.01.07 (03.01.07 Least Privilege · Privileged Functions) requires organizations to implement the following: Control Statement: SR-03.01.07.a Prevent non-privileged users from executing privileged functions. SR-03.01.07.b Log the execution of privileged functions. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.01.07.

NIST SP 800-53 Rev 5 control AC-4.21 (Physical or Logical Separation of Information Flows) is assessed by examining, interviewing, and testing: AC-4.21 · Physical or Logical Separation of Information Flows Control Statement: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Supplemental Guidance: Separate information flows logically or physically using [organization-defined parameter] to accomplish [organization-defined parameter]. Enforcing the separation of information flows associated with defined types of data can enhance protection by ensuring

NIST SP 800-53 Rev 5 control AC-4.6 (Metadata) is defined as follows: AC-4.6 · Metadata Control Statement: Enforce information flow control based on [organization-defined parameter]. Supplemental

Guidance: Enforce information flow control based on [organization-defined parameter]. Metadata is information that describes the characteristics of data. Metadata can include structural metadata describing data structures or descriptive metadata describing data content. Enforcement of allowed information flows based on metadata enables simpler and more effective flow control. Organizations consider the trustworthiness of metadata regarding data accuracy (i.e., knowled

NIST SP 800-53 Rev 5 control AC-18.4 (Restrict Configurations by Users) summarizes the requirements for this control: AC-18.4 · Restrict Configurations by Users Control Statement: Identify and explicitly authorize users allowed to independently configure wireless networking capabilities. Supplemental Guidance: Identify and explicitly authorize users allowed to independently configure wireless networking capabilities. Organizational authorizations to allow selected users to configure wireless networking capabilities are enforced, in part, by the access enforcement mechanisms employed within organizational syst